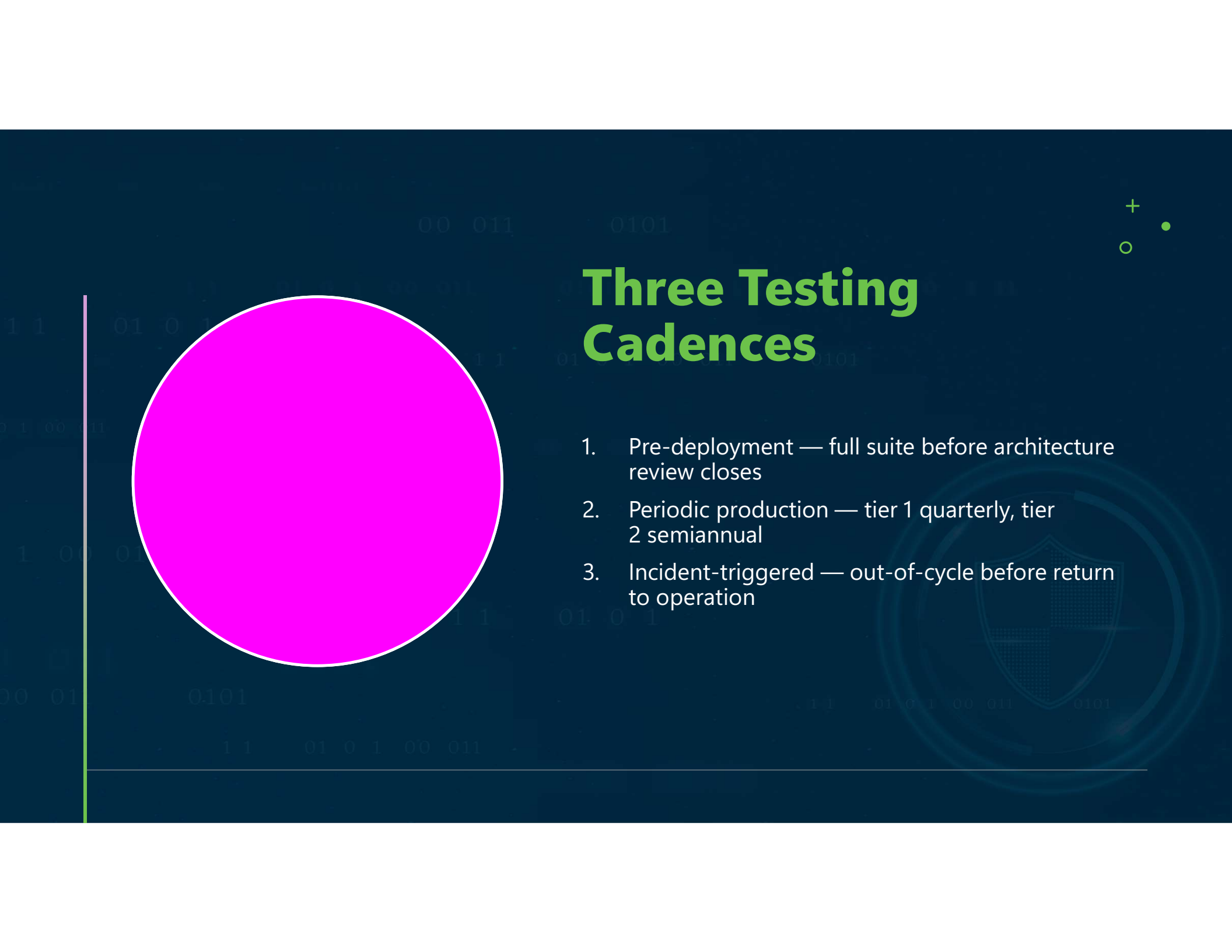


Model Testing, Regression & TEVV

Chapter 06 · Episode 1 — Dr. Michael Solomon





Three Testing Cadences

1. Pre-deployment — full suite before architecture review closes
2. Periodic production — tier 1 quarterly, tier 2 semiannual
3. Incident-triggered — out-of-cycle before return to operation

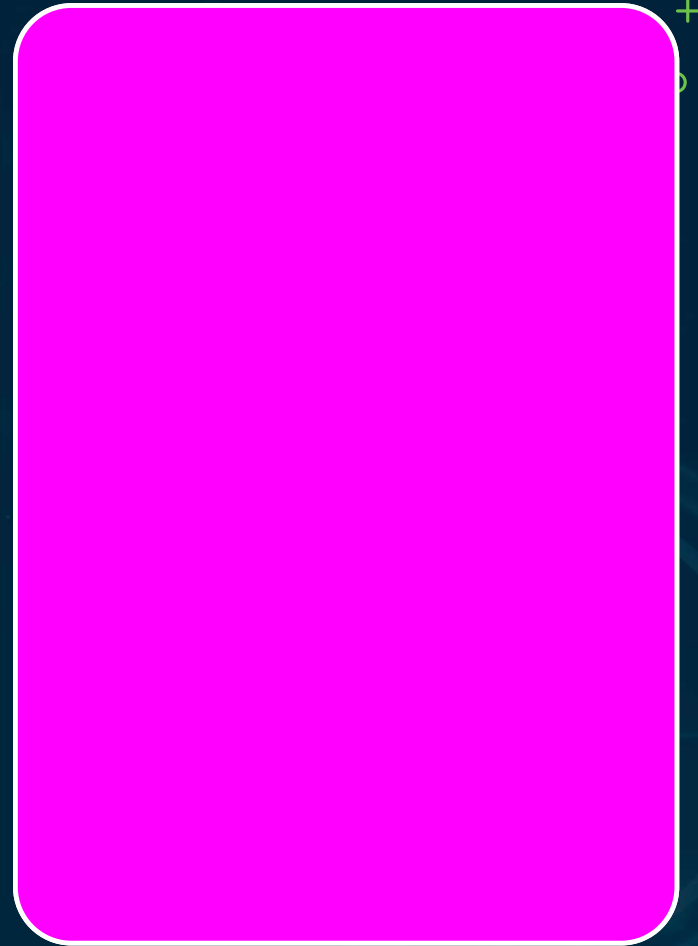
What This Episode Proves¹

Why accuracy alone is insufficient for security

Security-aware evaluation metrics

Adversarial robustness testing

Evaluation as a continuous control, not a one-time gate

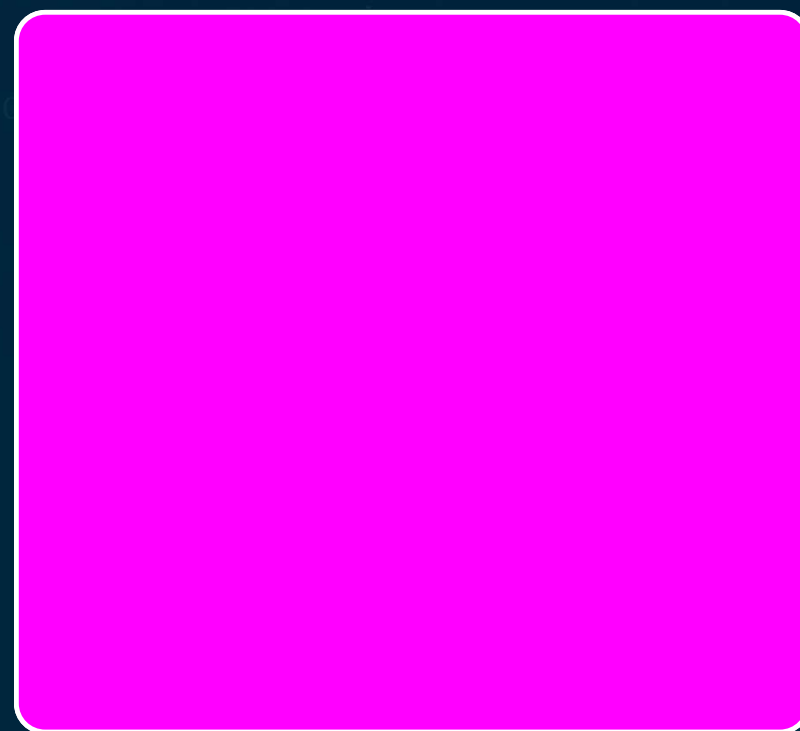


ACCURATE $\neq$ SECURE

Accuracy = average performance on the test distribution

Security = resilience under adversarial pressure

A 97%-accurate IDS can still be trivially evaded

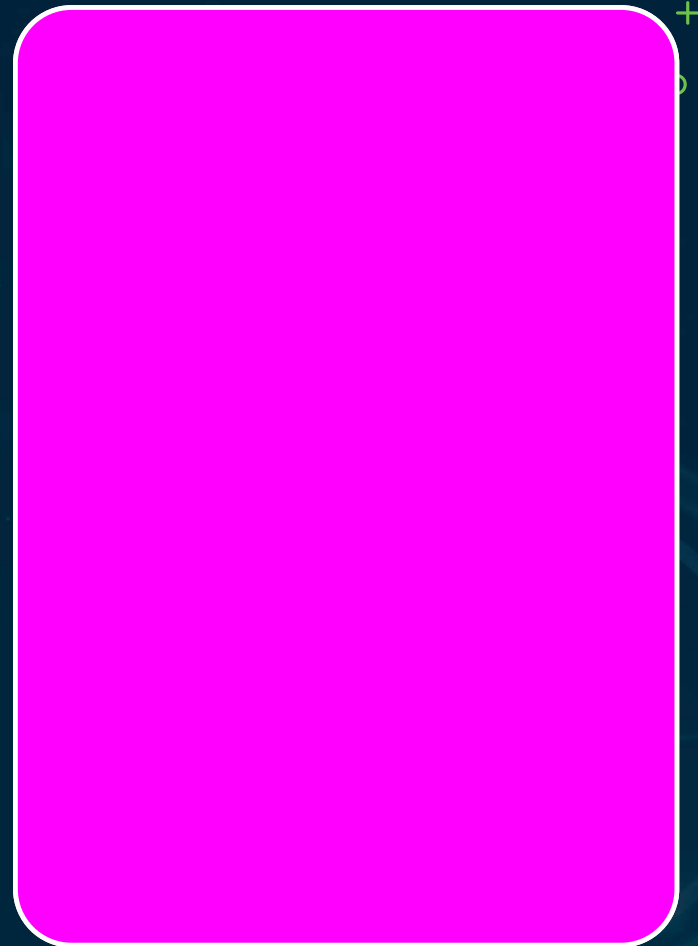


Metrics Must Reflect Asymmetry

A false positive inconveniences; a false negative enables a breach

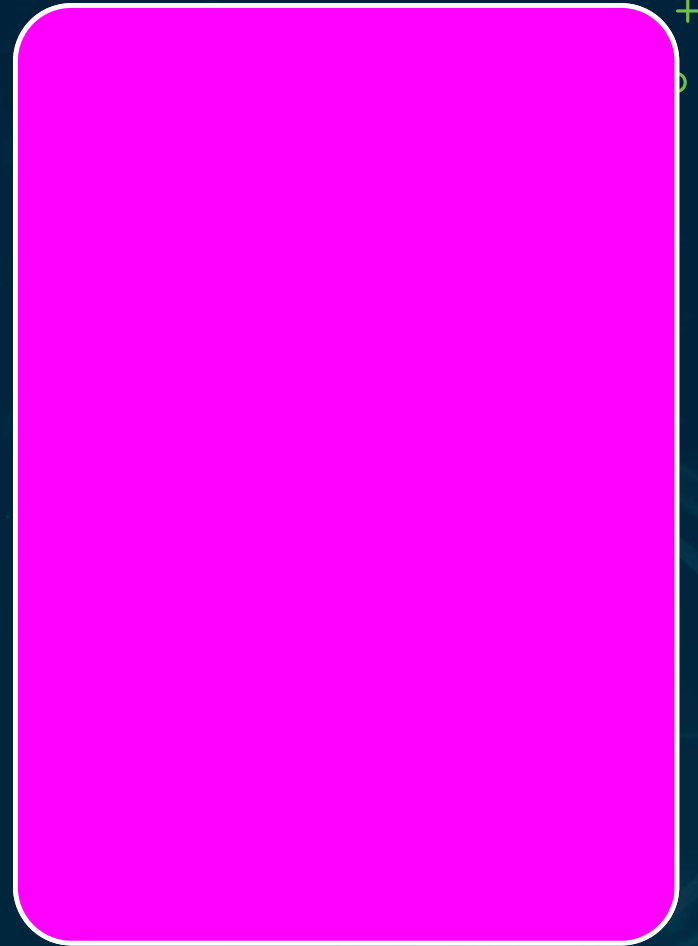
Precision & recall matter more than overall accuracy

FN rate on highest-severity threats = security posture



Independent Evaluation Data

- Train/eval independence is non-negotiable
- Holdout sets are the only honest baseline
- Cross-validation catches overfitting holdout misses

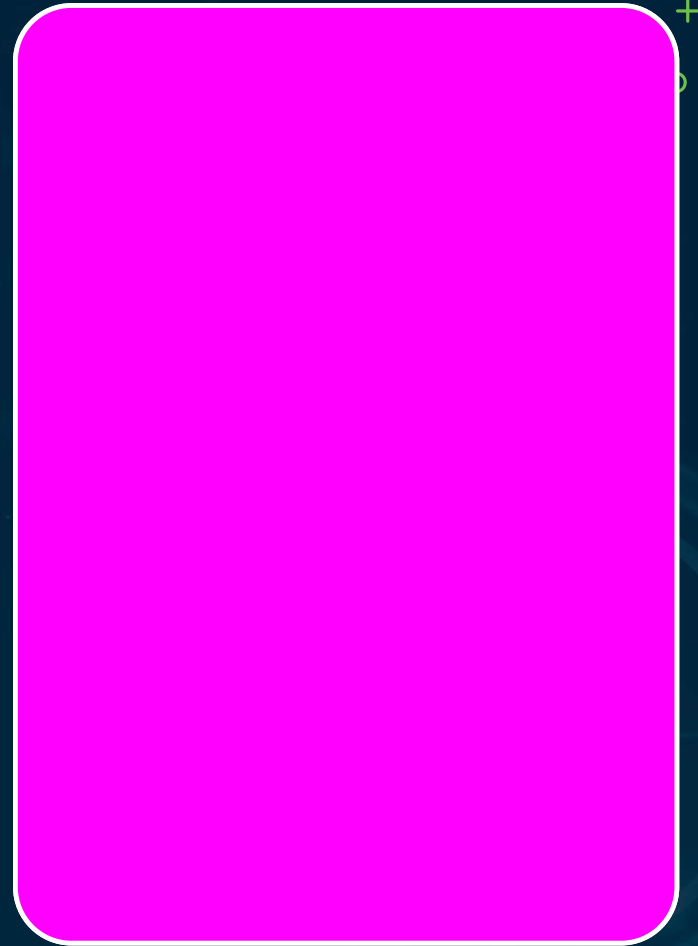


Evaluation Bias

Clean lab data fails on noisy production data

Include edge cases, out-of-distribution inputs, realistic noise

Why models that pass testing degrade after deployment



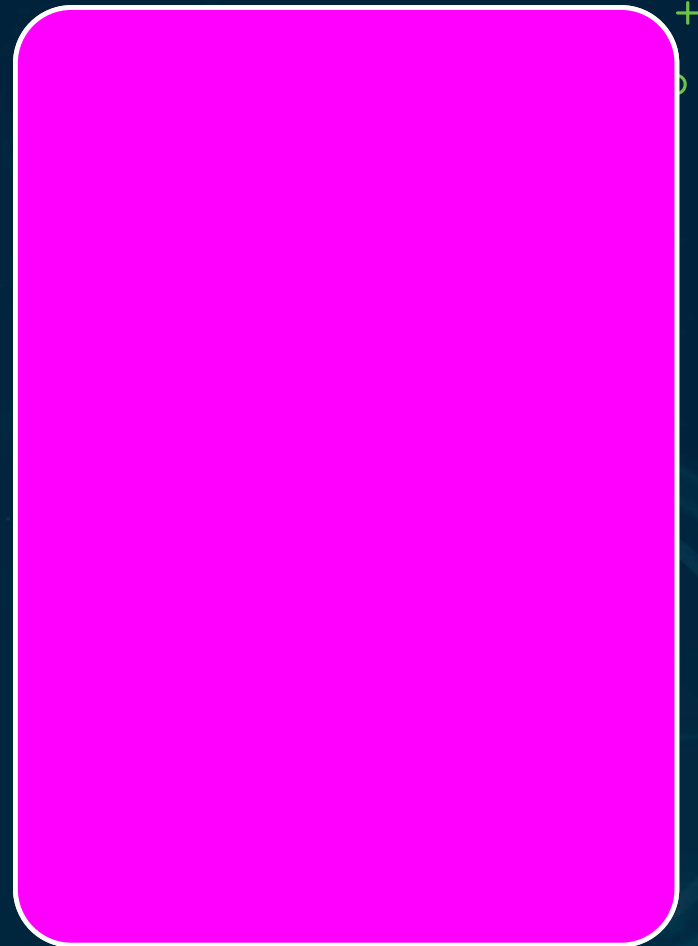
Adversarial Robustness Testing

Adversarial-example testing probes decision boundaries

Stress testing — unusual formats, extreme/ambiguous inputs

Red teaming — injection, prompt extraction, jailbreak, leakage

Guardrail validation under adversarial pressure

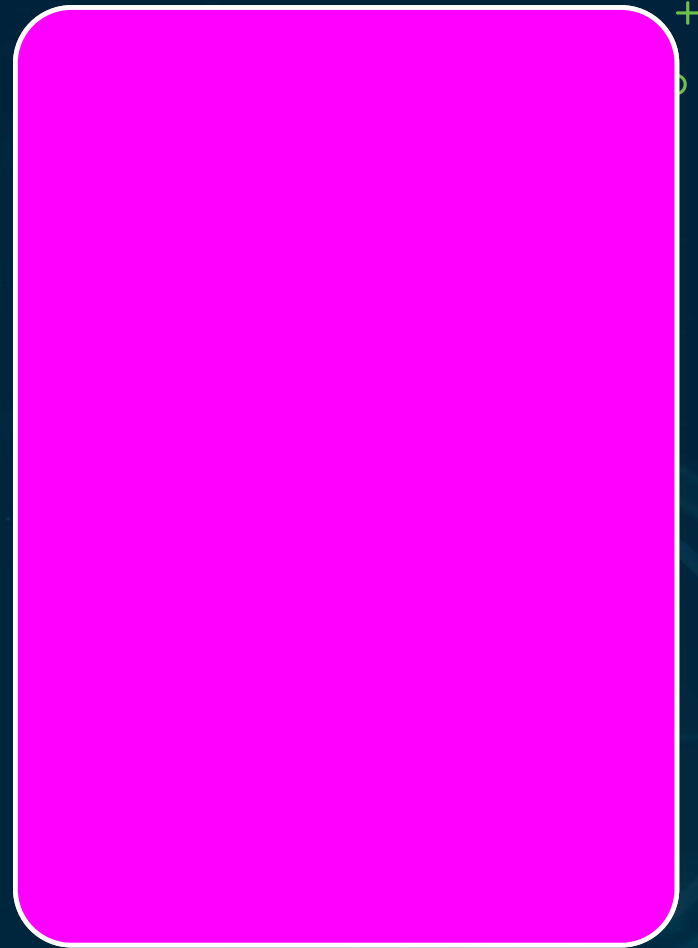


Bias, Fairness & Explainability

Bias is a security vulnerability — a known evasion path

Inconsistent fairness is what attackers look for

Explainability enables root-cause of unexpected outputs



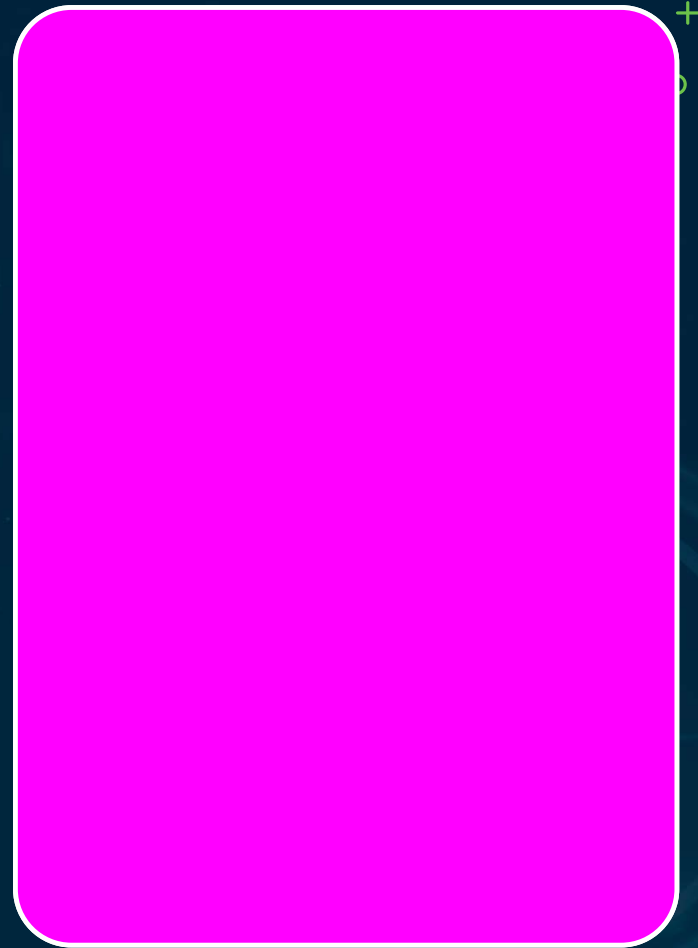
Evaluation Is Continuous

Not a pre-deployment gate — a continuous control

Post-deploy monitoring: drift, confidence, anomaly rates

Regression test after retrain, fine-tune, prune, quantize

Each optimization is a new deployment event



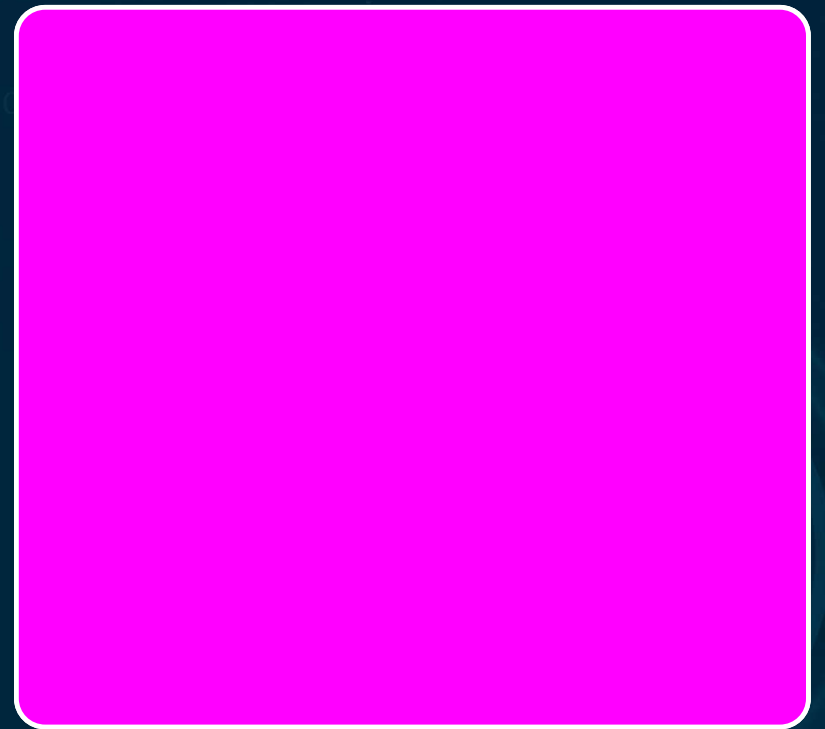
TEVV = DEPLOYMENT GATE



Findings above threshold become risk-register entries

V&V completion gates the architecture-review checklist

Mandatory for high-risk AI under the EU AI Act

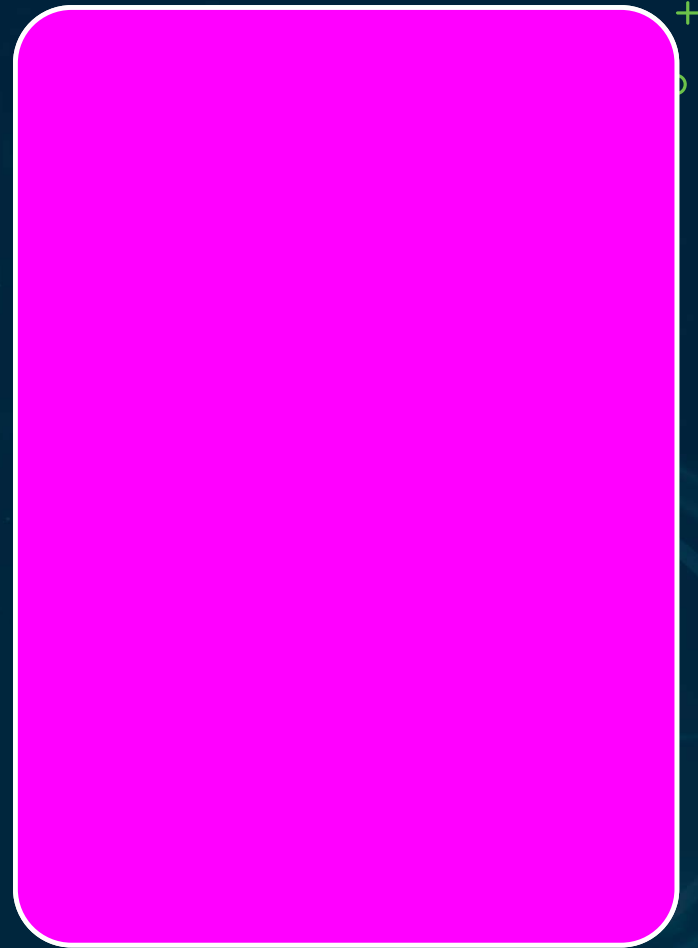


Encryption: Data at Every Stage

Training data, model artifacts, inference —
all sensitive

Three states: at rest, in transit, in use

The exam tests all three independently



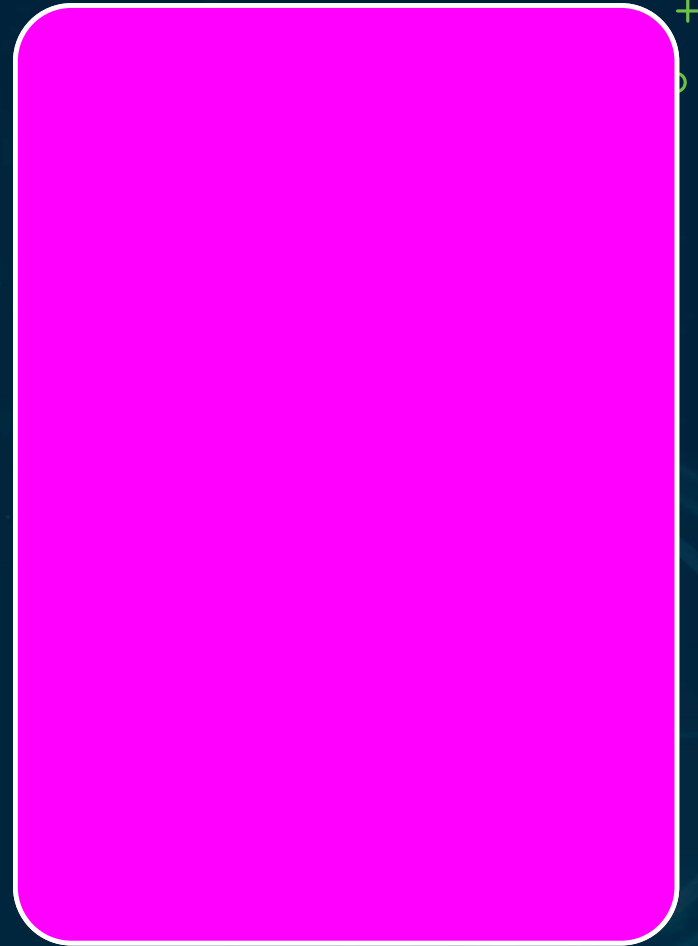
Encryption at Rest

Encrypt training data, corpora, vector DBs,
model weights

Storage-level + application-level layers

Key governance: isolate keys from data;
KMS rotation

Readable data on stolen media = at-rest failure



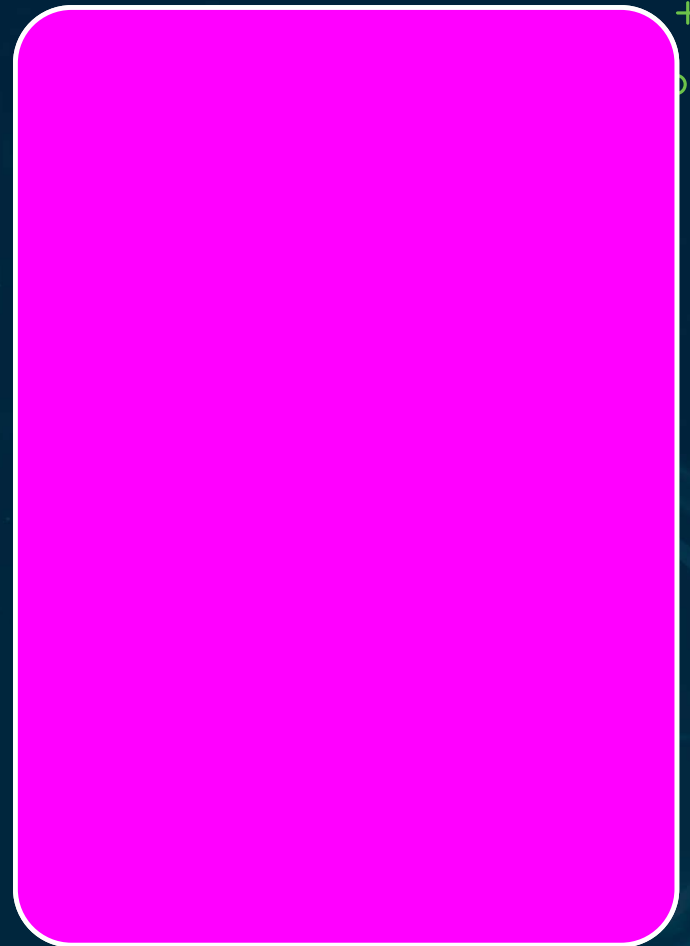
Encryption in Transit

TLS for all distributed AI communication — a rule, not advice

Mutual authentication for service-to-service

Certificate-lifecycle management; zero-trust internally

Intercepted traffic = in-transit failure



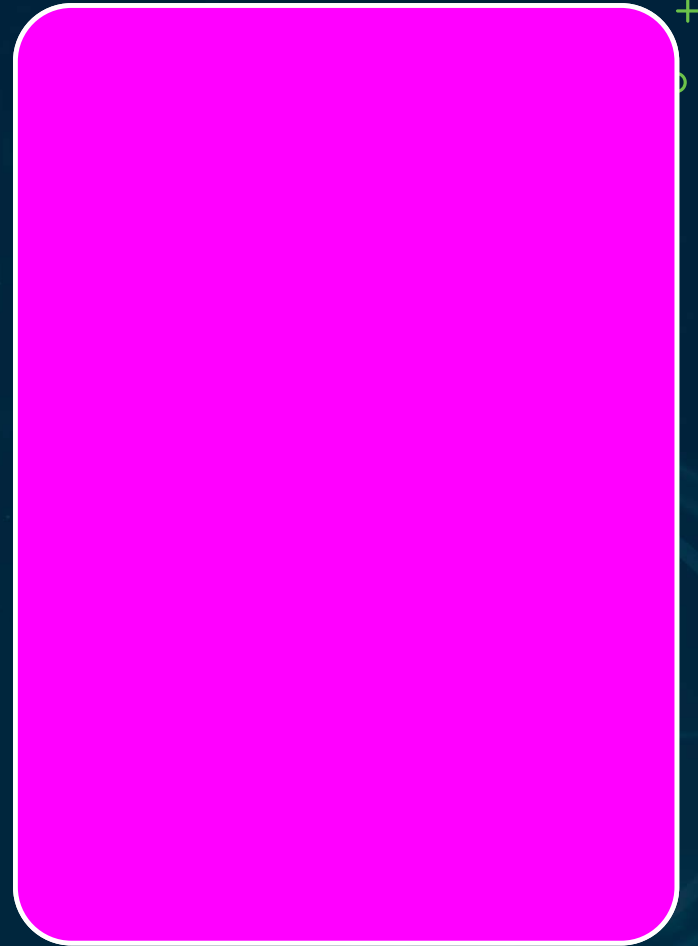
Encryption in Use

Confidential computing / trusted execution environments

Isolates memory in multi-tenant cloud

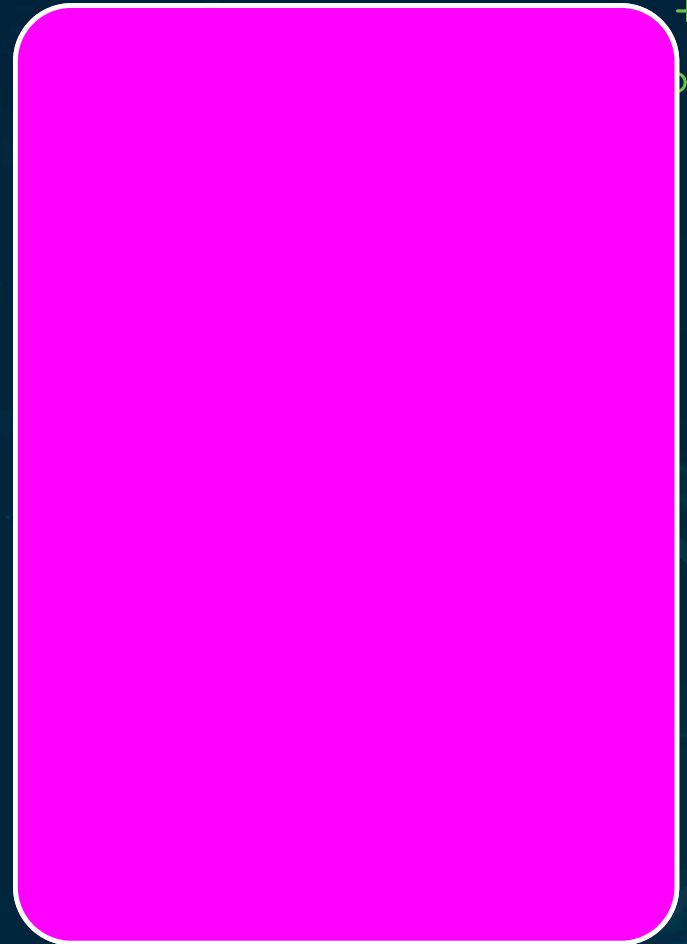
Homomorphic encryption — compute on encrypted data

Leakage despite rest + transit = in-use lacking



Key Governance & Lifecycle

Key rotation, revocation, crypto-operation logging
Regulatory alignment for protected data categories
Encryption without key governance is insufficient
One layer of defense-in-depth, not a standalone answer

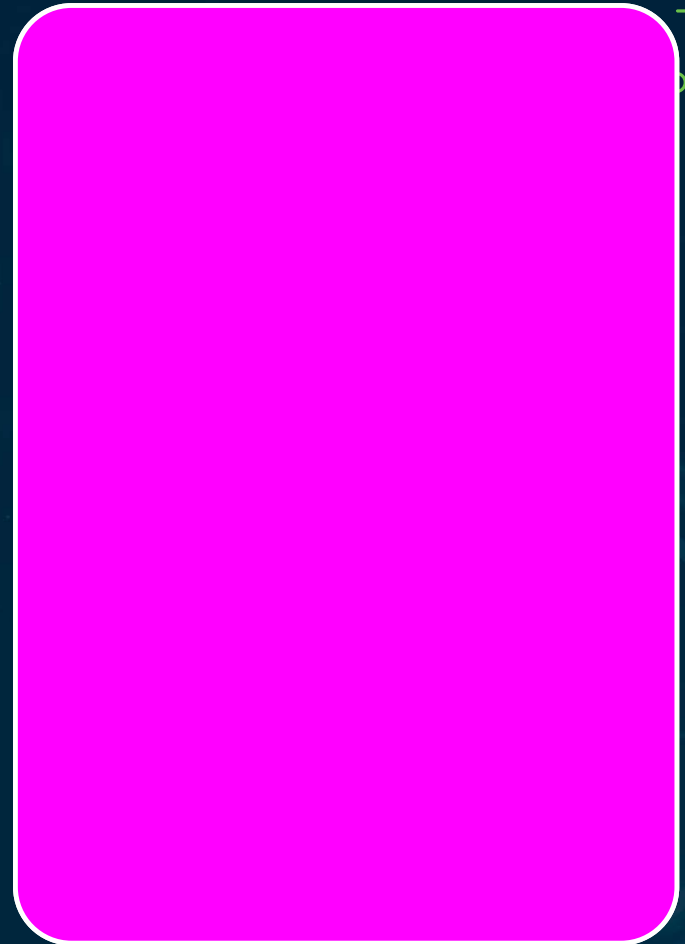


Recap · Testing & TEVV

Five testing categories: functional, performance, adversarial, fairness, regression

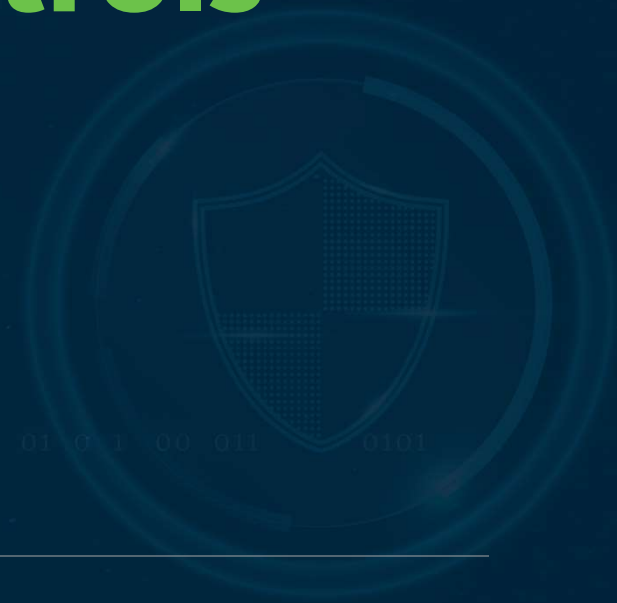
TEVV + the V&V distinction

Regression testing is a mandatory gate after every material change



Data Management Controls & Data Poisoning

Chapter 06 · Episode 2 — Dr. Michael Solomon



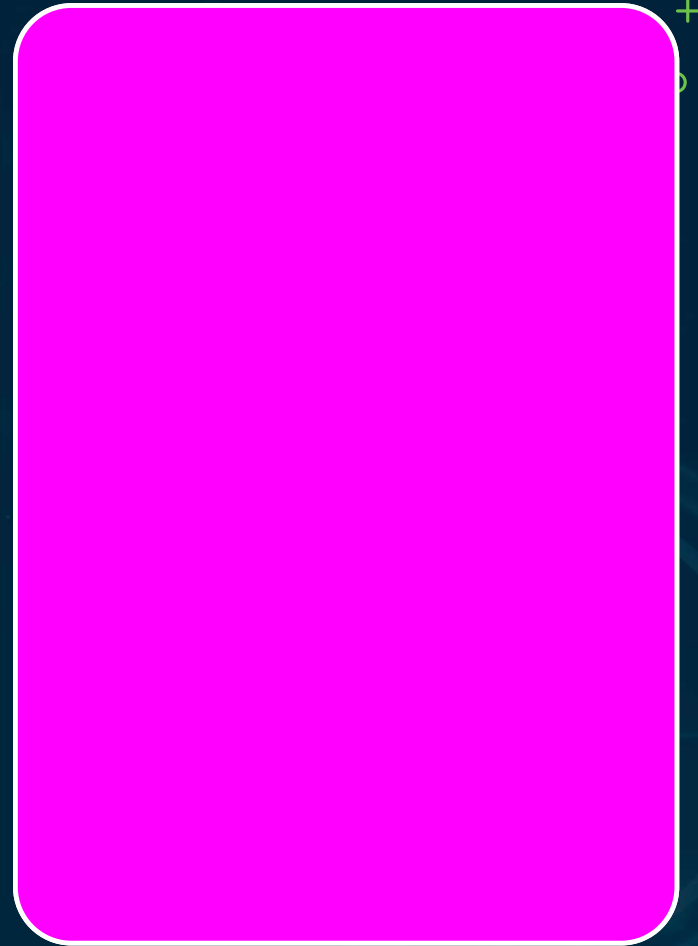
Data Governance — Program Connections

Classification aligns with AI-asset-inventory tiers

Access controls reflected in per-system specs

Retention consistent with the training-data license register

Owned by the AI Compliance Analyst — not a standalone IT policy

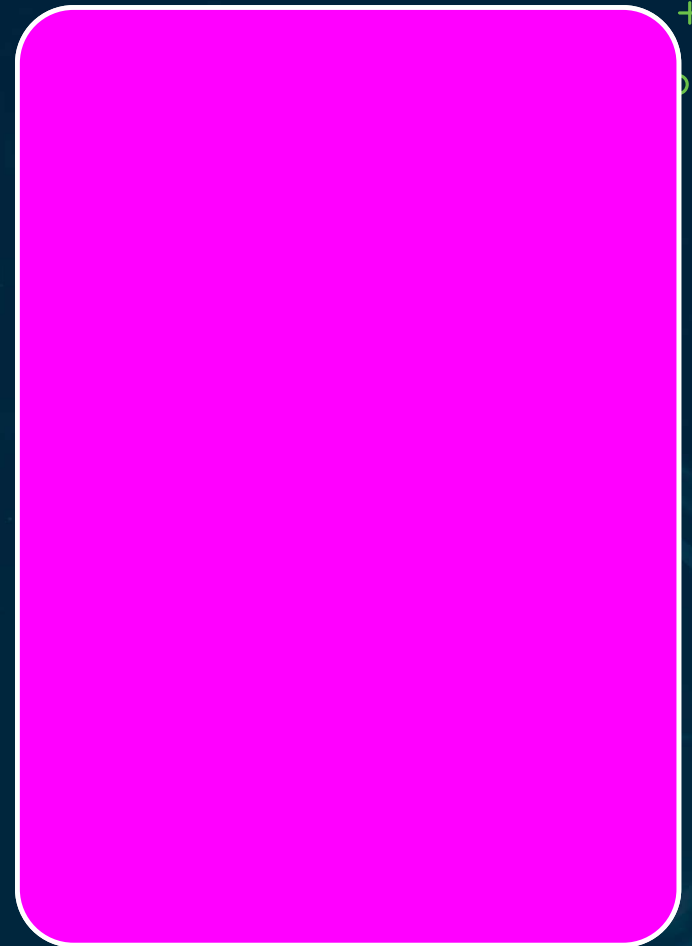


Why Data Is a Security Problem

Bad data creates bad models

Compromised data creates compromised models

Objectives: seven controls, quality → security,
pipeline integrity



Traditional AppSec vs AI Data-Origin

Traditional AppSec:

Vulnerability lives in the code

Fix = patch the code

Auditable — read the source

Point-in-time fixes

Attack surface = running app

AI Data-Origin:

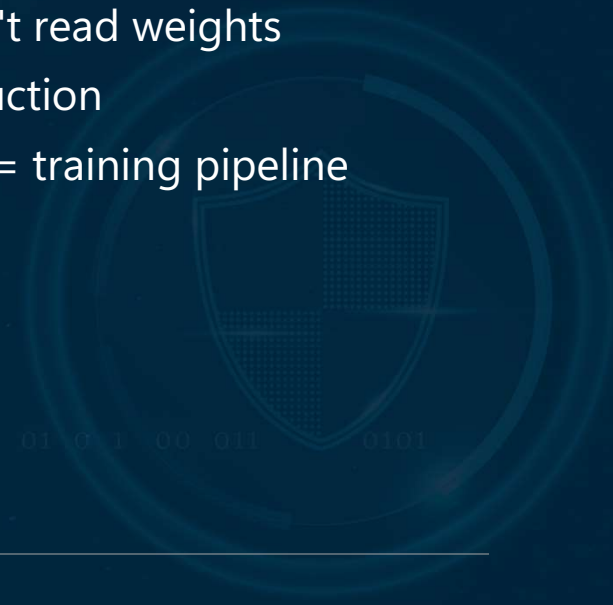
Encoded in model weights

Fix = full retraining

Opaque — can't read weights

Found in production

Attack surface = training pipeline

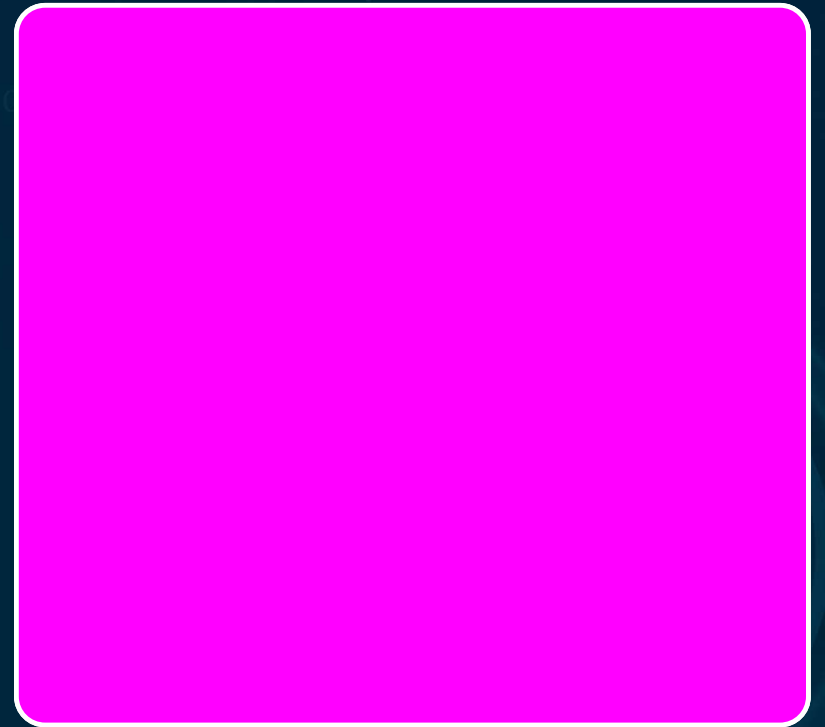


PREVENT BEFORE TRAINING



Prevention before training is the only cost-effective control

Data-processing controls ARE security controls



Seven Data Controls • 1–4



1 Cleansing

Remove invalid / duplicate
/ injected records



3 Lineage

Track journey source →
training



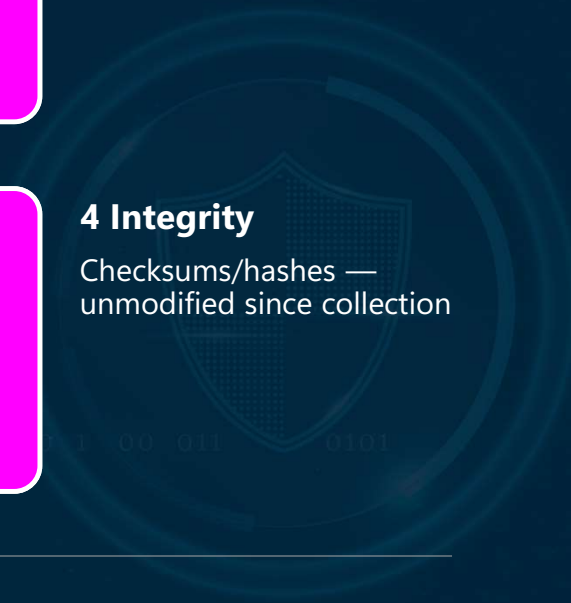
2 Verification

Confirm records are
authentic (semantic)



4 Integrity

Checksums/hashes —
unmodified since collection



Seven Data Controls · 5–7



1 Provenance

Original source legitimacy
+ authorization



3 Balancing

Proportional class
representation



2 Augmentation

Review augmented samples
for accuracy/bias



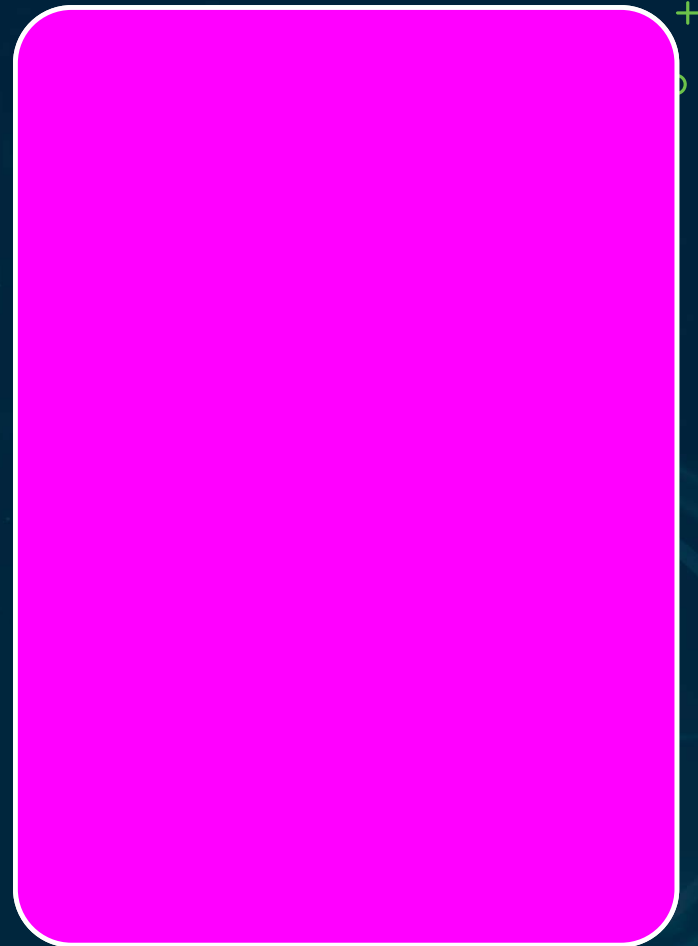
Controls 1–4 in Depth

Cleansing — structurally valid $\neq$ safe

Verification — catches semantic fakes
cleansing misses

Lineage — evidence chain for in-transit modification

Provenance — trusted source + license (EU AI Act)



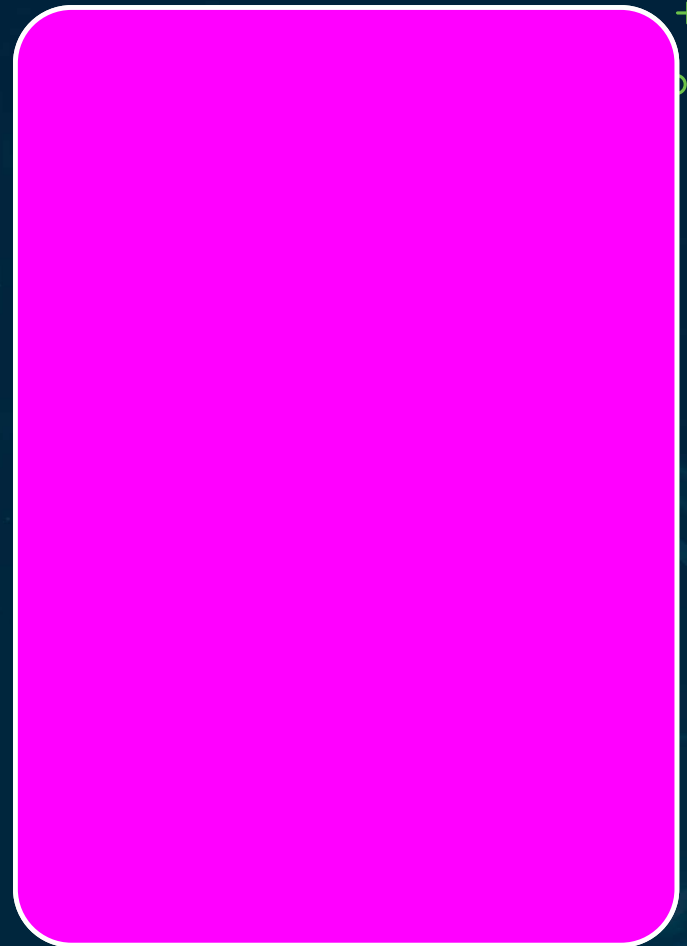
Integrity & Provenance

Hash or sign at collection; verify before training

Checksums simplest; cryptographic signatures stronger

Provenance = security + compliance (EU AI Act, GDPR)

Provenance documents are part of the audit trail



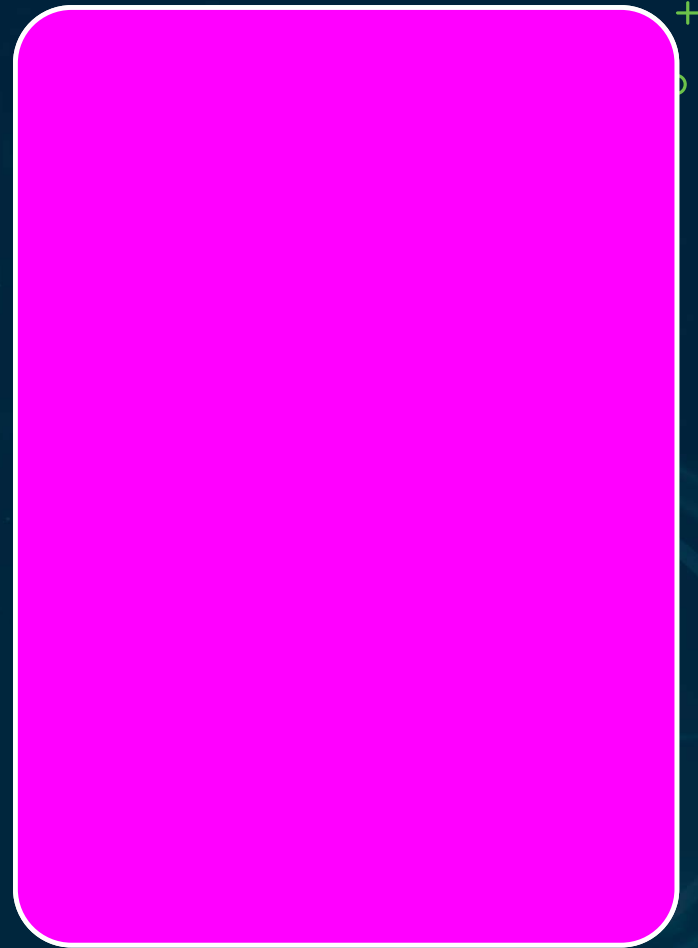
Augmentation & Balancing Risks

Augmentation can introduce systematic distortion

Review augmented samples stay unambiguous

10,000 : 100 balance = a false-negative factory

Imbalance creates predictable blind spots



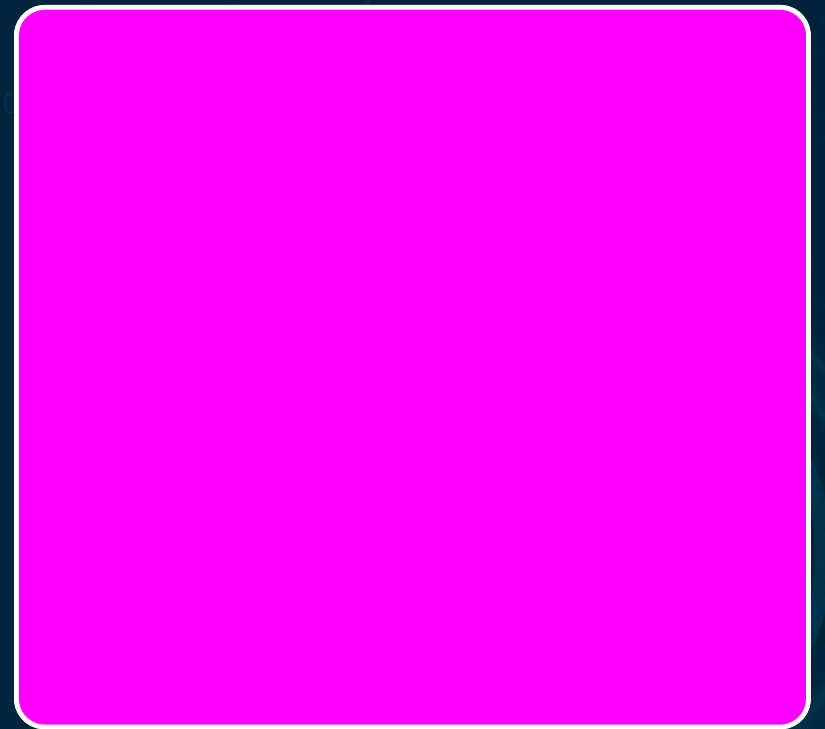
PROVENANCE = LICENSE + FORENSICS



Proactive: evidence base for the license register

Reactive: primary forensic artifact for poisoning

Store write-once / immutable; preserve
before remediation



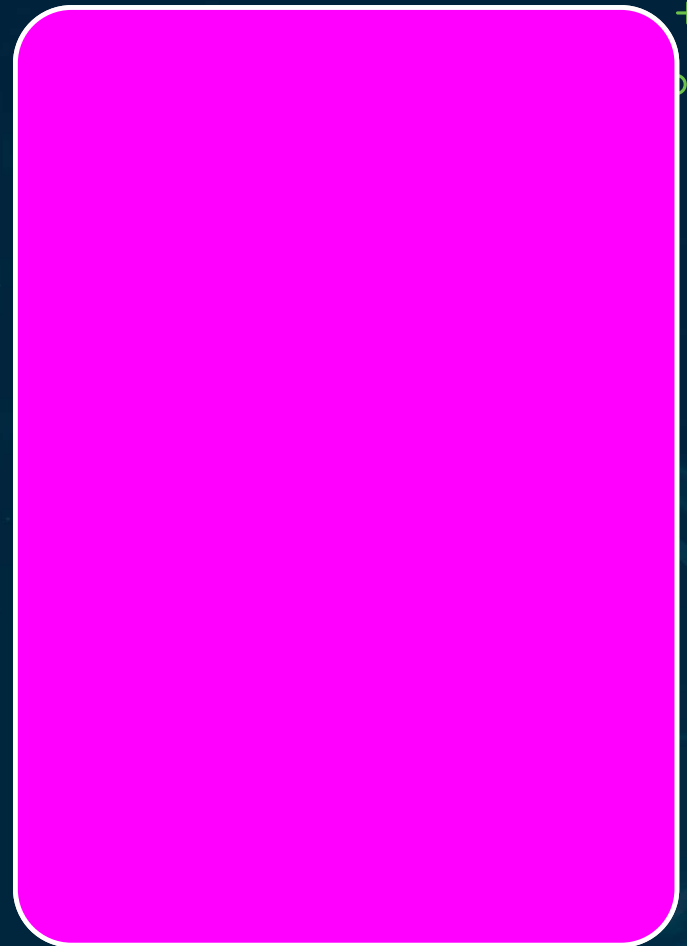
Three Data Types

Structured — PII memorization risk

Semi-structured — schema inconsistency
fools cleansing

Unstructured — highest risk; extractable
via prompting

Classify + redact before training

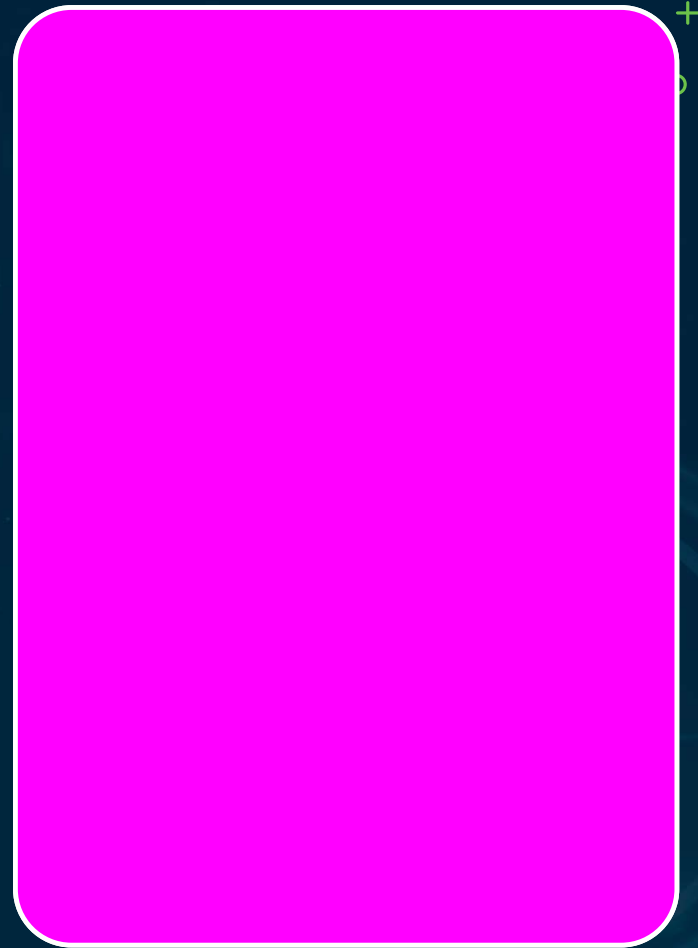


Retrieval-Augmented Generation (RAG)

Augments responses with retrieved external knowledge

Query → embedding → vector search → context → response

Update knowledge without retraining the model



RAG Attack Surface



Query

Crafted query retrieves sensitive docs

Retrieval

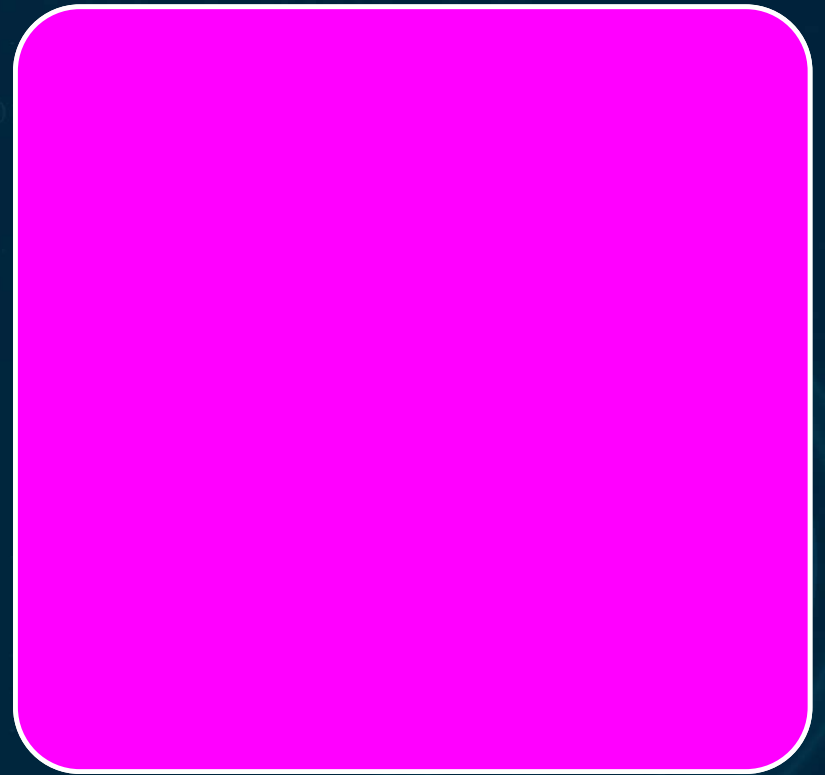
Poisoned knowledge base = indirect injection

Augmentation

Model can't tell trusted from hostile

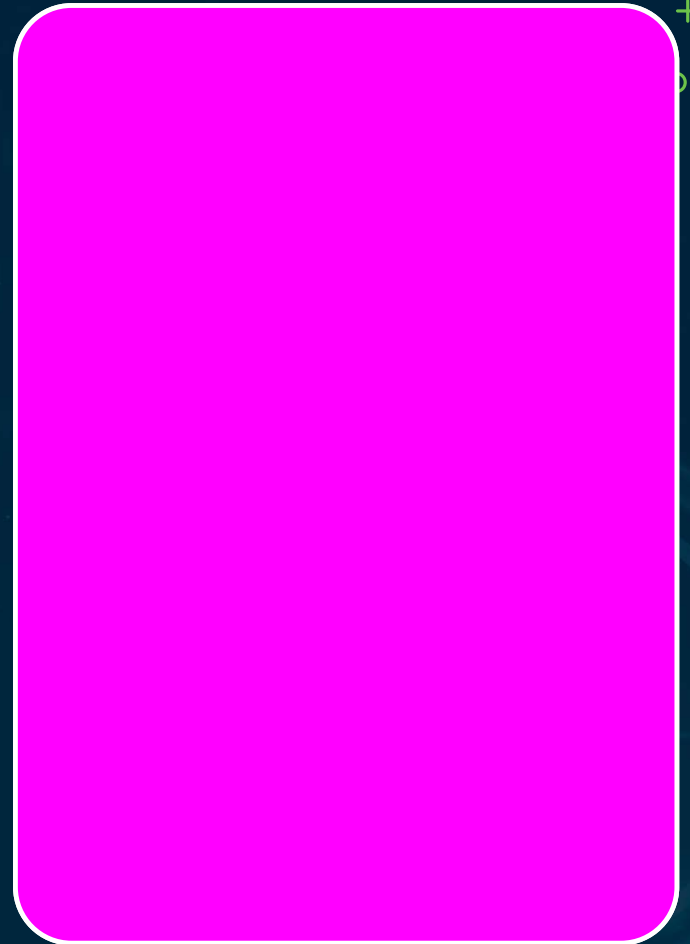
Generation

Retrieved sensitive content leaks in output



RAG Controls & Embeddings

- Vector-DB access control; validate before injection
- Output filtering; scope retrieval by user permission
- Embeddings encode semantic meaning as vectors
- Similar concepts sit near each other in vector space



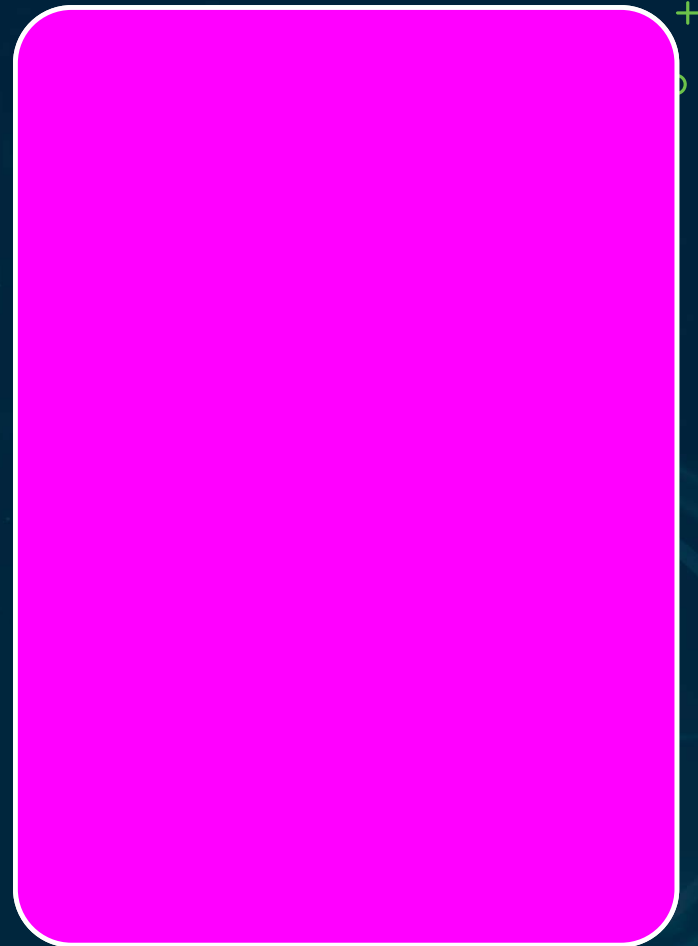
Vector Stores & Watermarking

Vector-store access control = document access control

A compromised vector store enables targeted retrieval

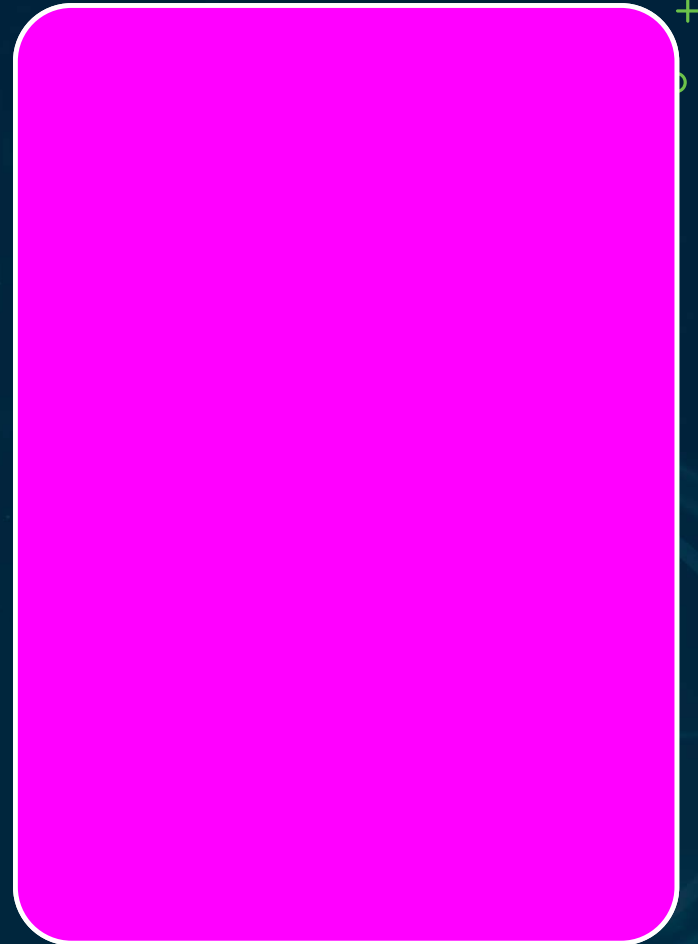
Training-data watermarking detects unauthorized dataset use

Model-output watermarking marks & traces AI content

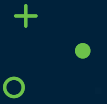


Five Data-Poisoning Response Steps

- 1 Classify as Category A + assess severity
- 2 Preserve evidence (provenance, weights) first
- 3 Red-button activation if in production
- 4 Forensics — affected batches, versions, outputs
- 5 Recovery — rollback if clean; retrain if integrity unconfirmed



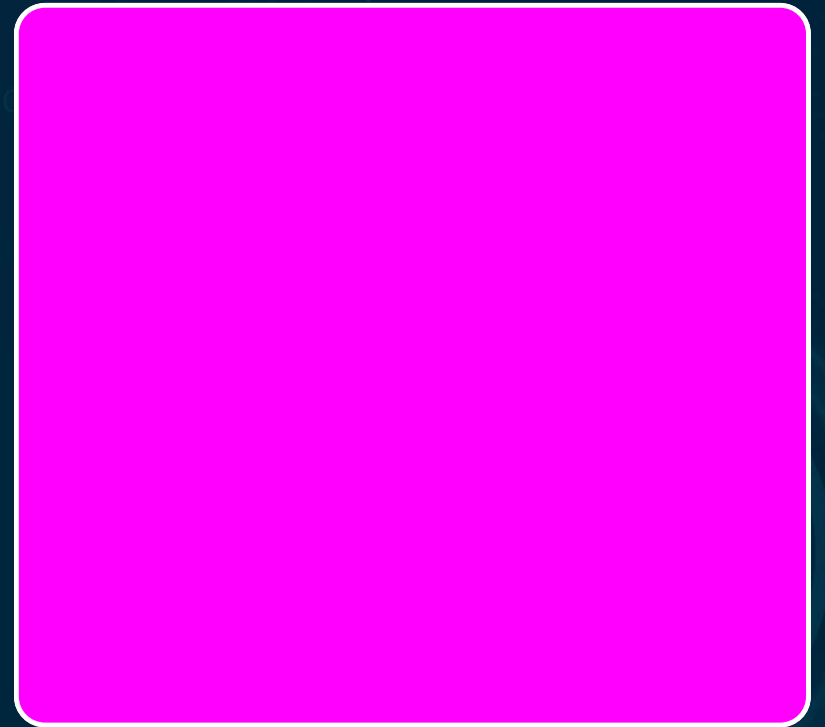
INTEGRITY $\neq$ CONFIDENTIALITY



Encryption protects confidentiality; integrity protects trust

A silently modified dataset can be catastrophic

Enforce integrity across the entire lifecycle



Integrity Controls

Reproducibility and tamper detection are both required — different integrity purposes

CONTROLS

- ◆ **Cryptographic hashing** — unique fingerprint of dataset state; one changed record changes the hash
- ◆ **Immutable storage** — write-once or append-only blocks modification after write
- ◆ **Change detection** — monitors datasets and alerts on unexpected modification
- ◆ **Version control** — each training cycle references a documented dataset state

EXAM CONTENT

- ◆ Reproducibility is essential — forensic retraining needs the original dataset state preserved
- ◆ Alteration goes undetected → hashing or change-monitoring controls were absent
- ◆ Data-layer corruption propagates upward into model behavior
- ◆ Version control supports integrity verification **and** audit trail requirements

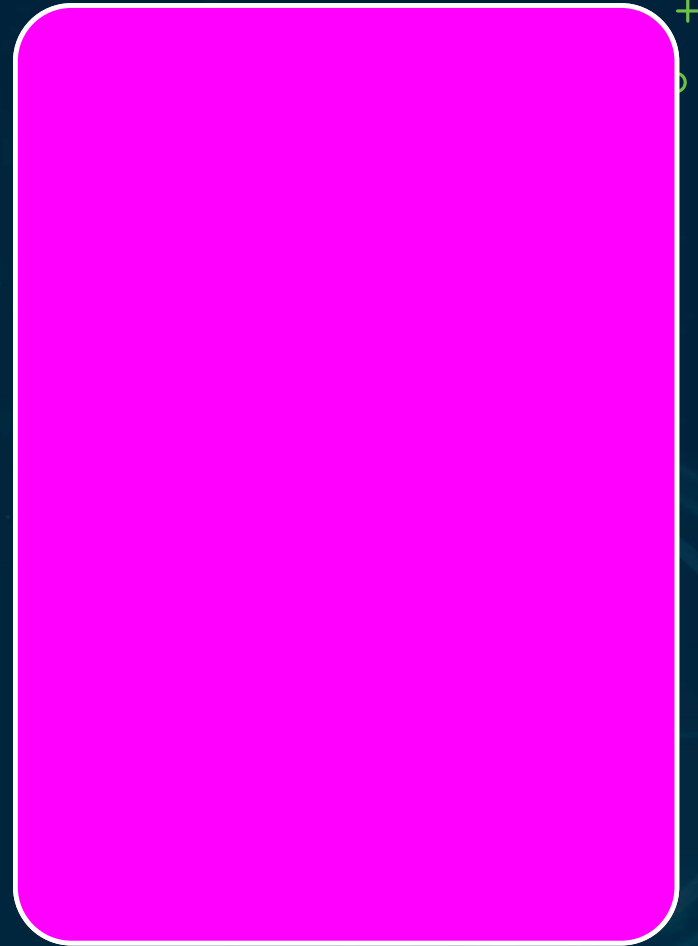
Output Protection

Output validation — unaltered
before users/workflows

Secure logging — append-only,
timestamped, verifiable

Digital signatures on high-value outputs

Altered AI evidence = insufficient logging integrity

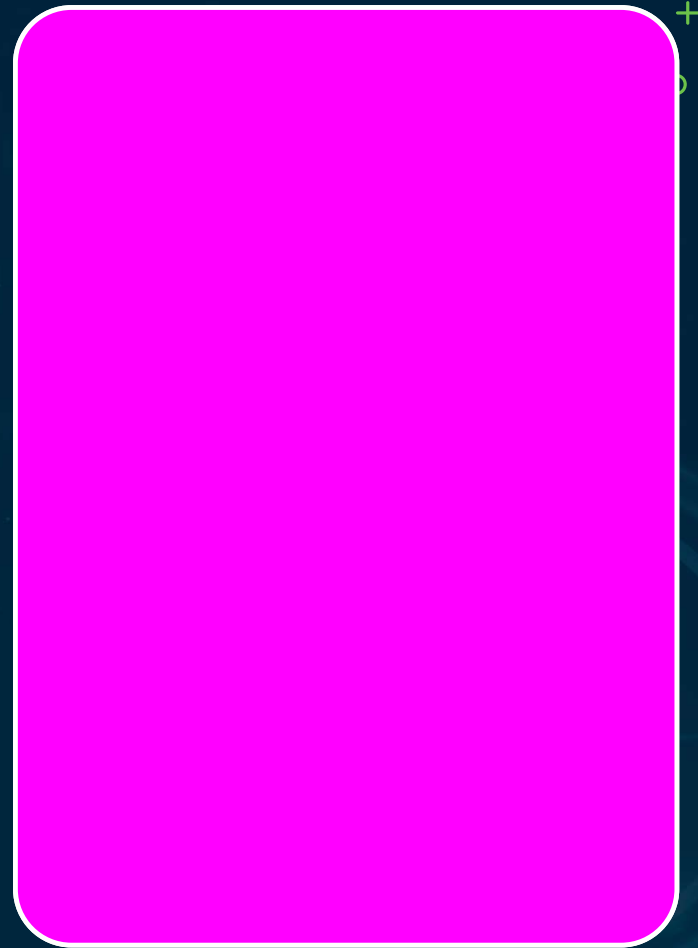


Authenticity & Provenance

Watermarking distinguishes authentic from manipulated output

Provenance tracks dataset origin + training lineage

Detect unauthorized model reuse via provenance comparison



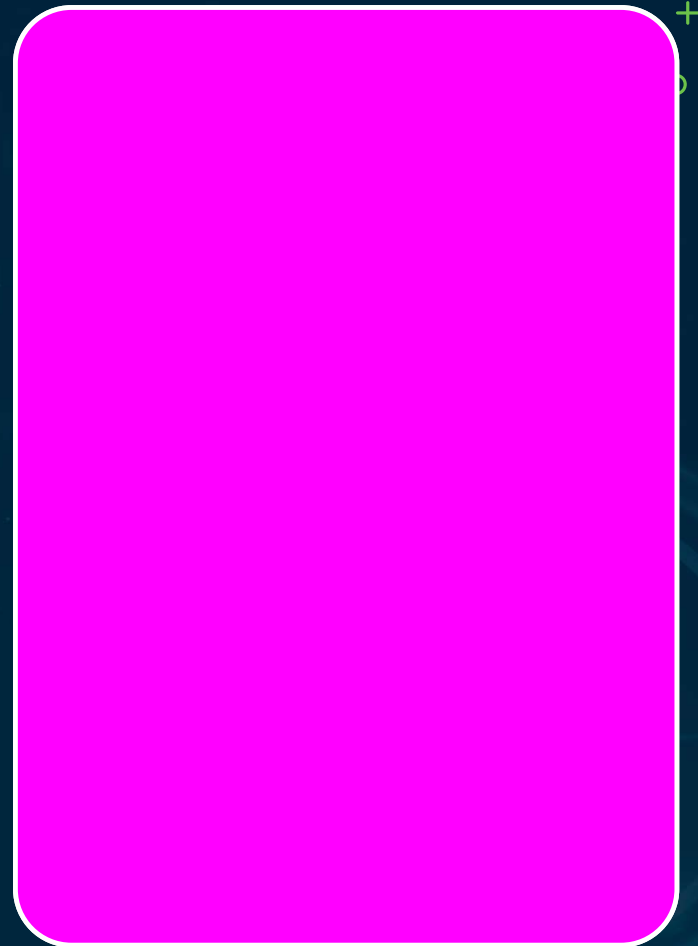
Continuous Integrity Monitoring

Anomaly detection on datasets, configs, parameters

Drift without authorized retraining may
signal tampering

Rollback to known-good states; integrate with
incident response

Detection alone is insufficient without restoration



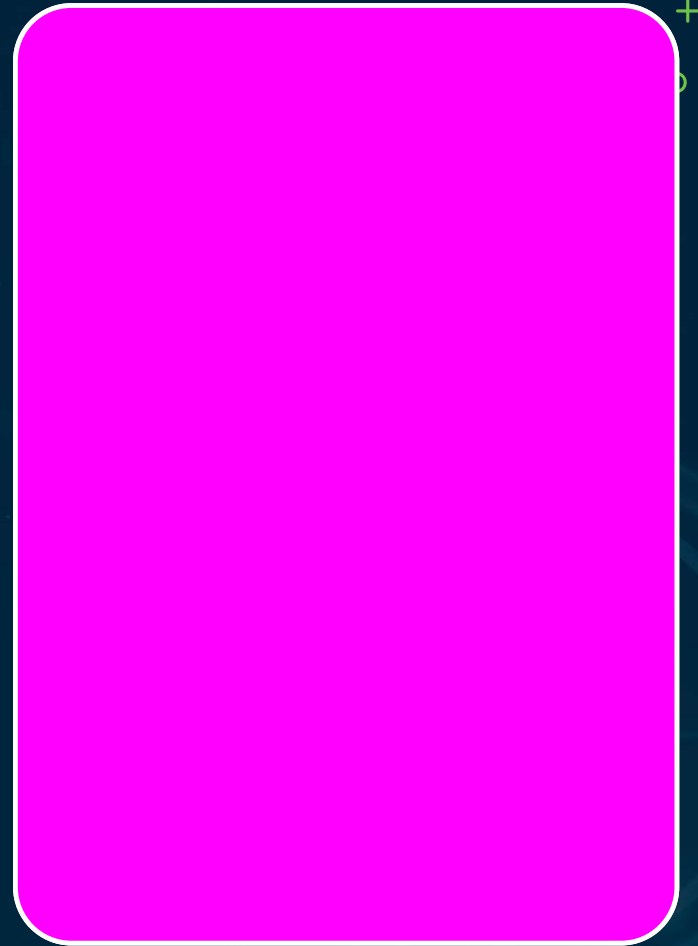
Recap · Data Management

Data-governance policy program connections

Provenance is immutable + required for the license register

Data poisoning = Category A — the highest-impact attack

Five data-poisoning response steps



Privacy, Ethical & Trust Controls

Chapter 06 · Episode 3 — Dr. Michael Solomon



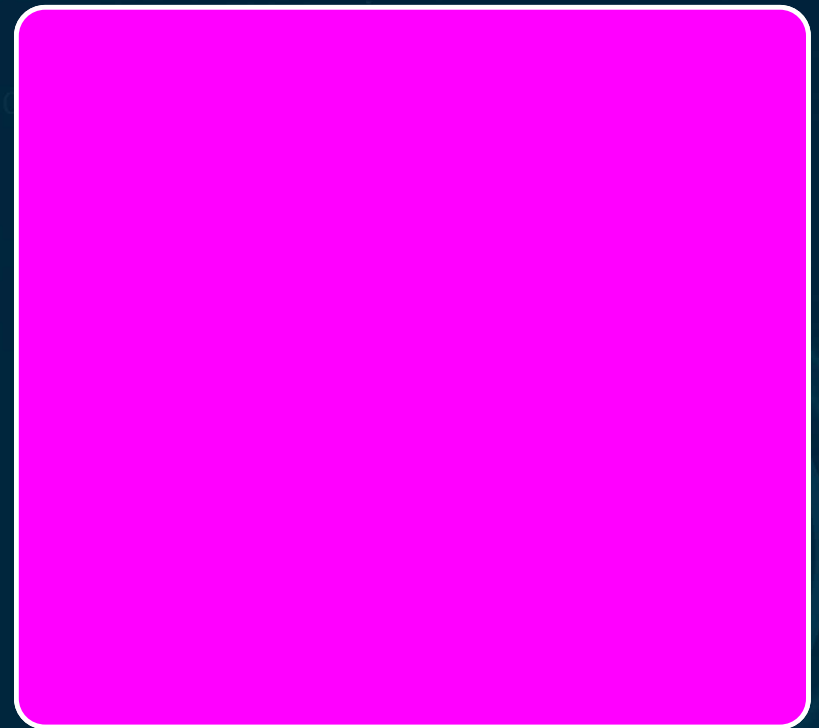
ASPIRATIONAL vs TESTABLE

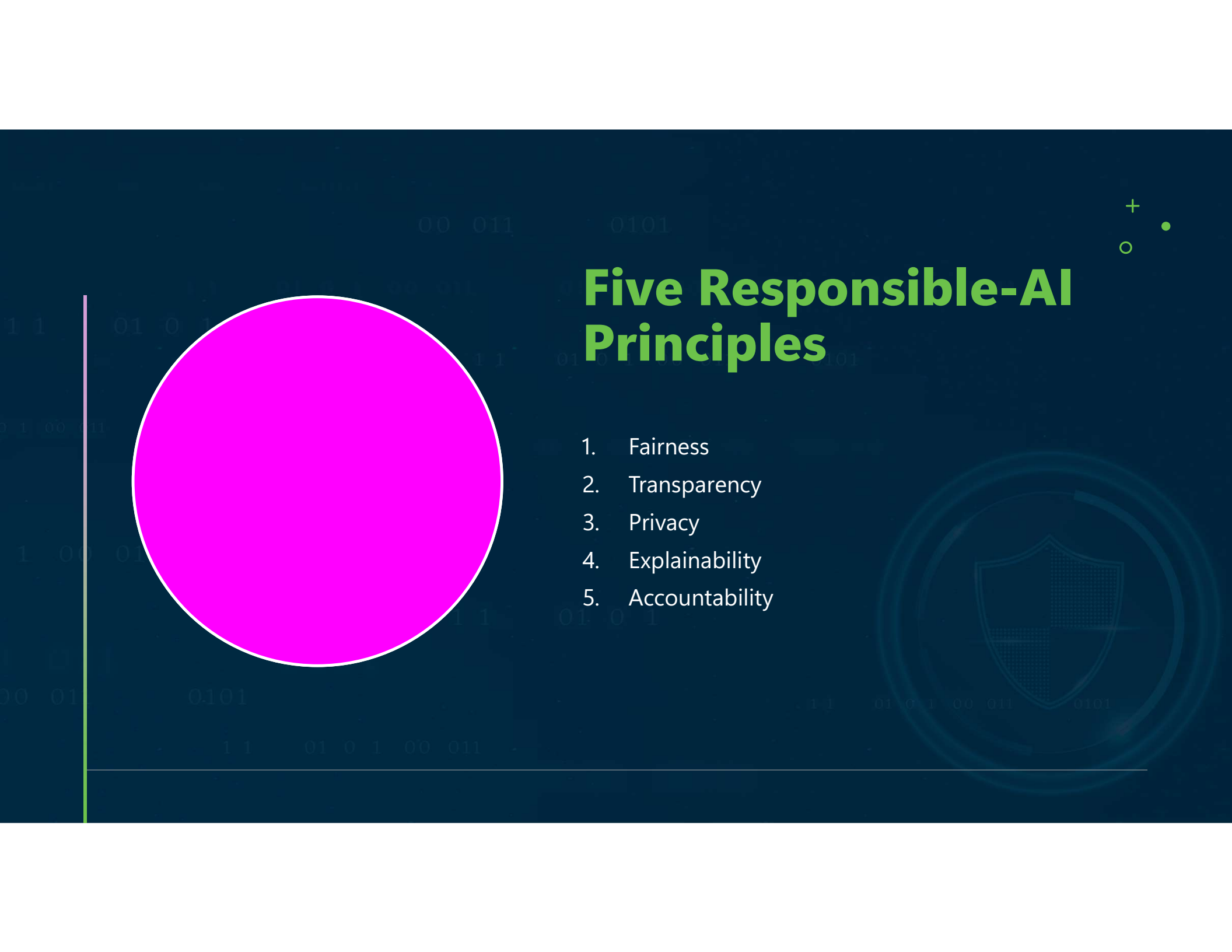


Every principle needs a testable control

Five elements: control, metric, threshold, cadence, owner

Principles without these are just intentions





Five Responsible-AI Principles

1. Fairness
2. Transparency
3. Privacy
4. Explainability
5. Accountability

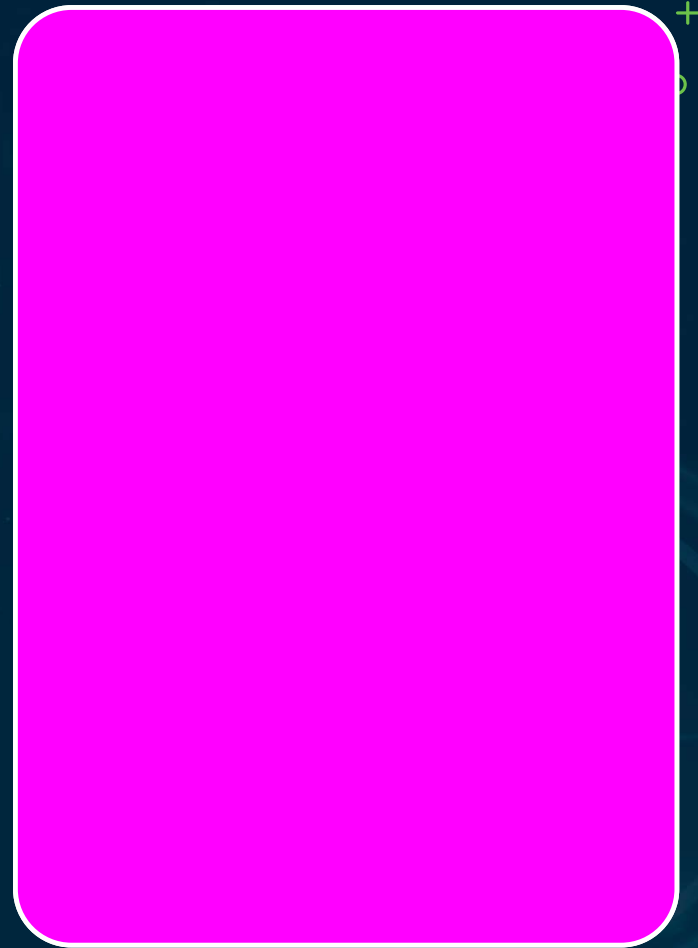
Fairness

Demographic parity — equal positive-outcome rates

Equal opportunity — equal error rates (esp. false negatives)

Violated when rates differ without legitimate justification

e.g. fraud flagging skewed across groups



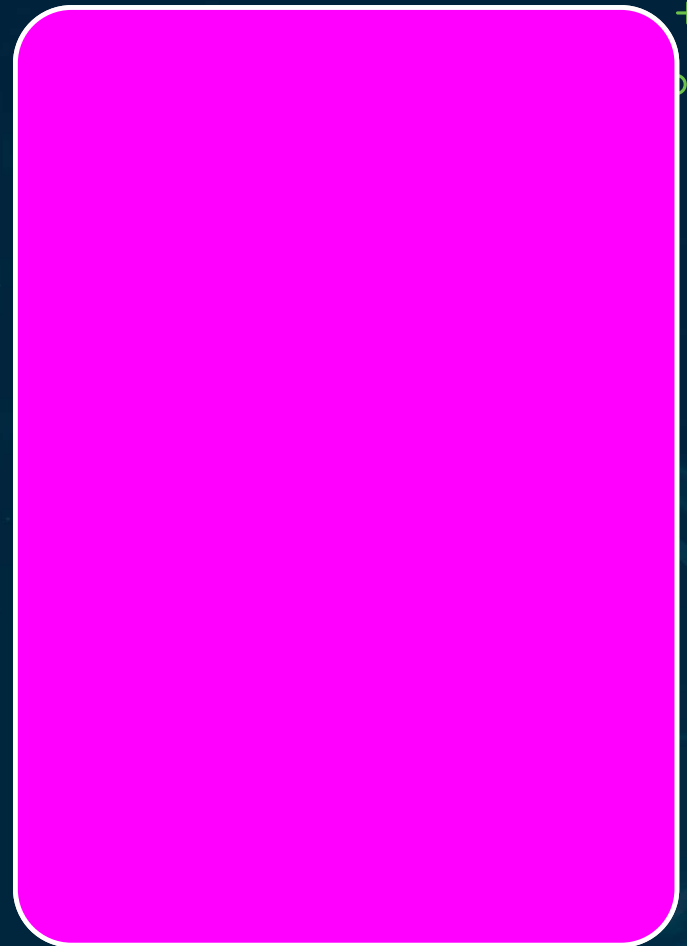
Transparency

Communicate existence, purpose, capabilities, limits

Not full disclosure of model internals

Regulated: credit, healthcare, employment

Violated when decision-making is hidden



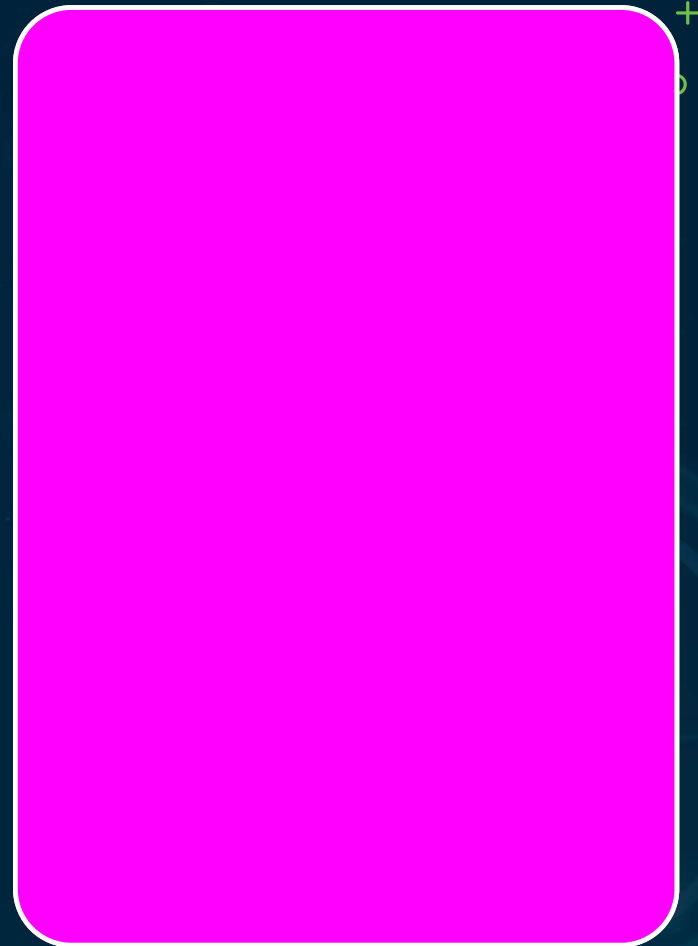
Privacy — Three AI-Specific Risks

Inference attacks — infer sensitive attributes

Training-data memorization — reproduce personal data

Re-identification of anonymized data via correlation

Privacy by design: minimization, purpose limits, consent



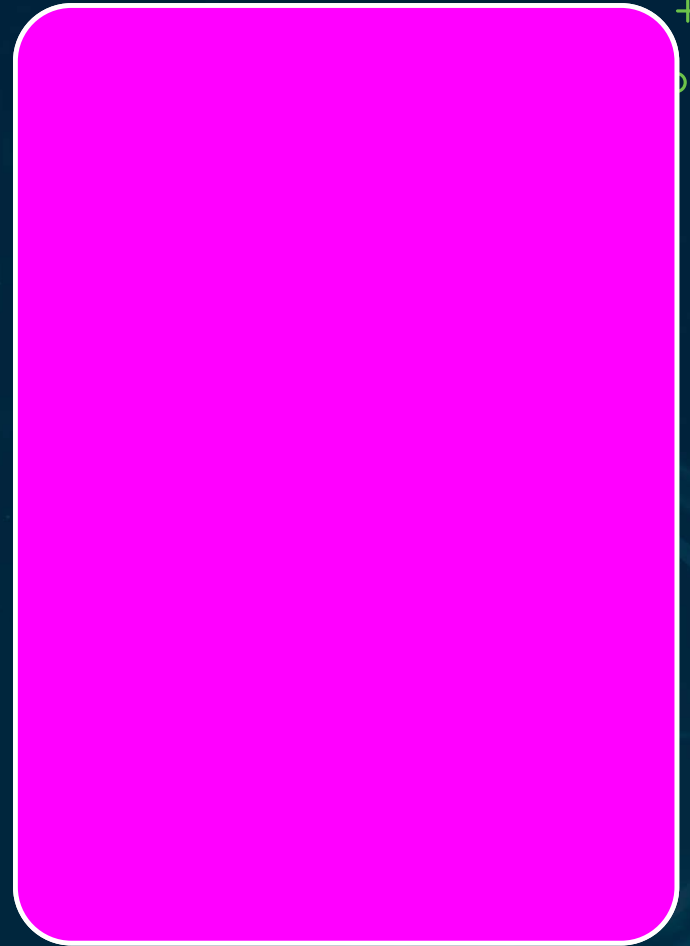
Explainability

Meaningful human account of a specific decision

Explainability $\neq$ interpretability (full internals)

LIME — local approximation with a simpler model

SHAP — feature-contribution scores via game theory

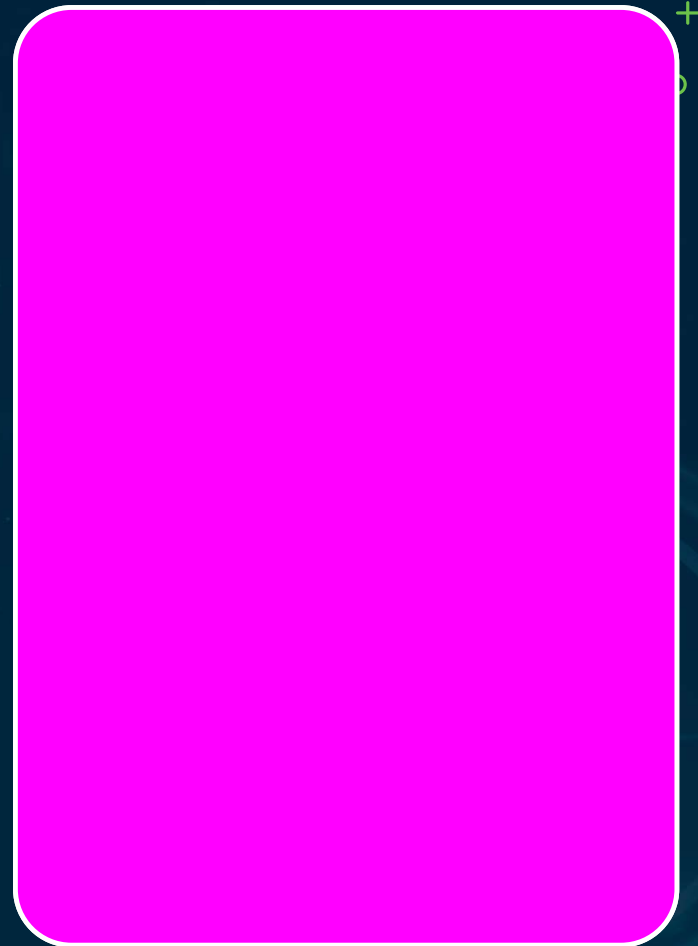


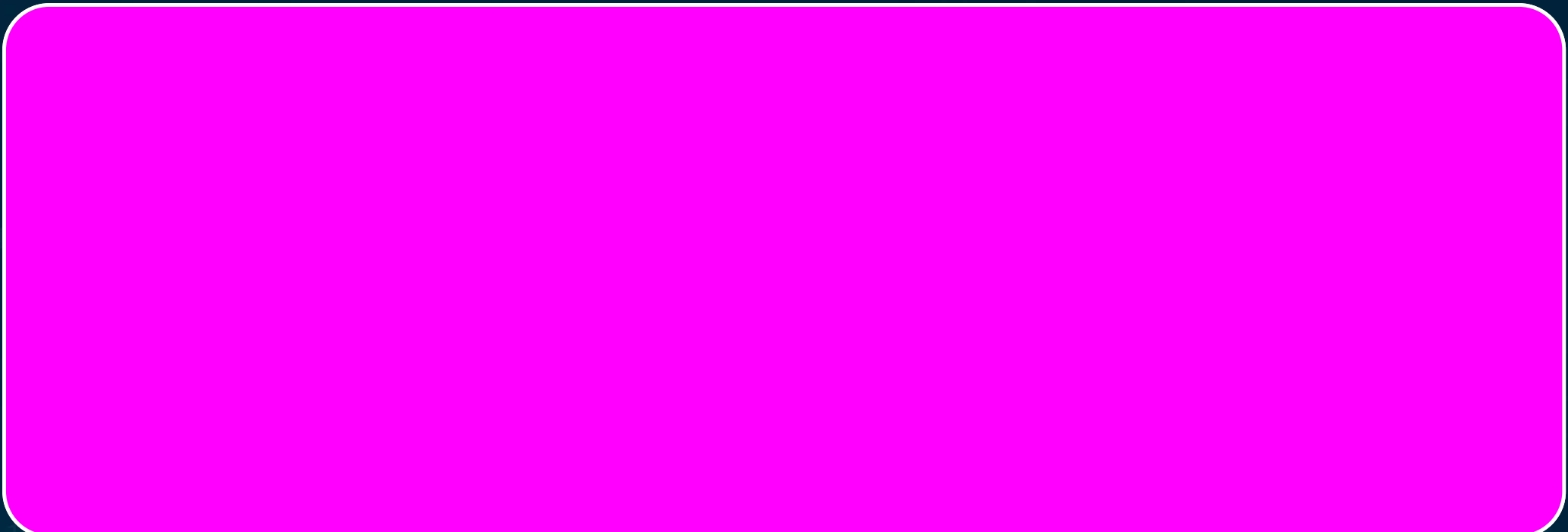
Accountability

Clear role ownership + audit trails

Governance that attributes decisions to responsible parties

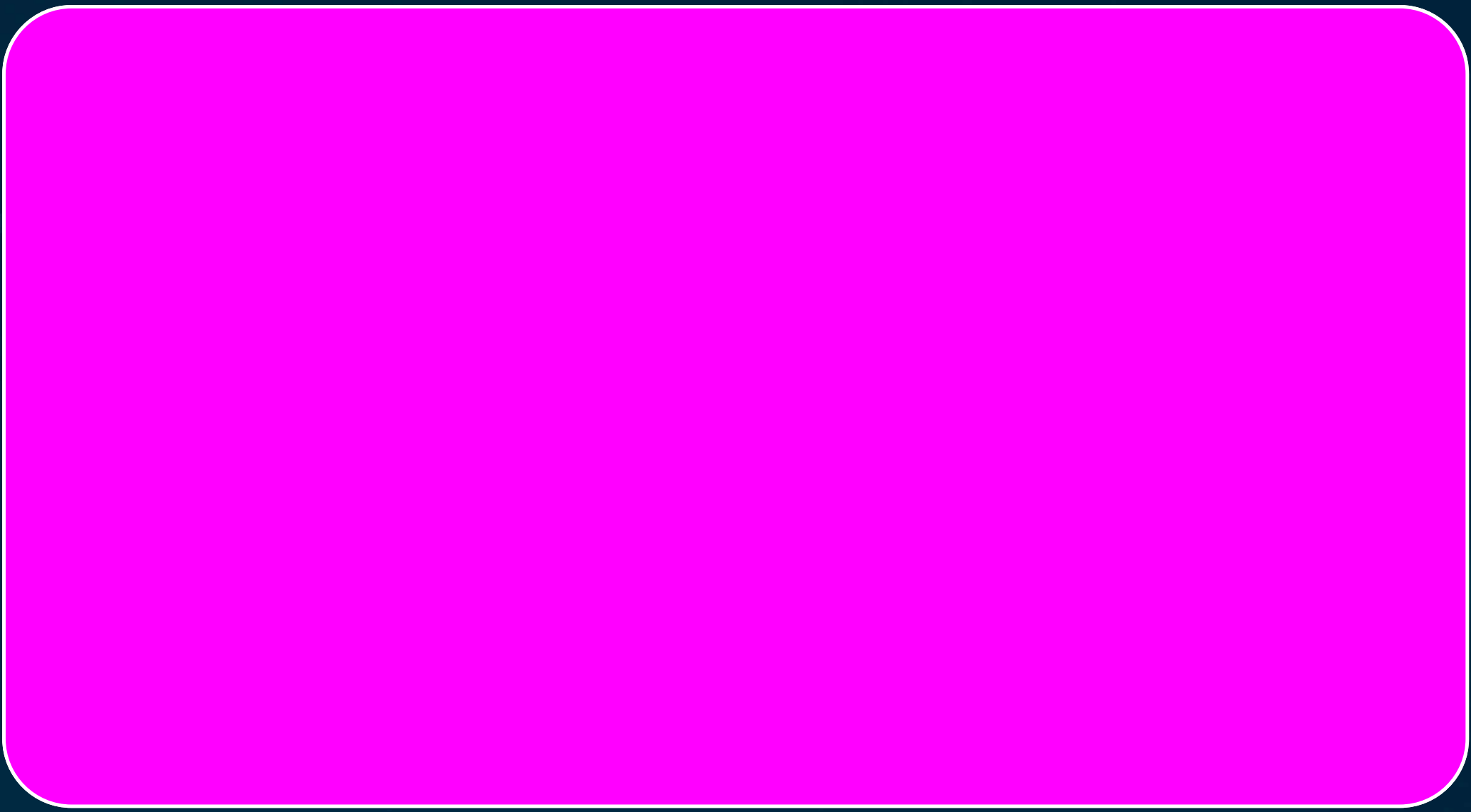
Completes the responsible-AI framework





Demo · Responsible-AI Scorecard

Evaluate an AI system against all five principles in Google Colab — fairness (parity + equal opportunity), the three privacy risks, and LIME/SHAP — producing a compliance scorecard.



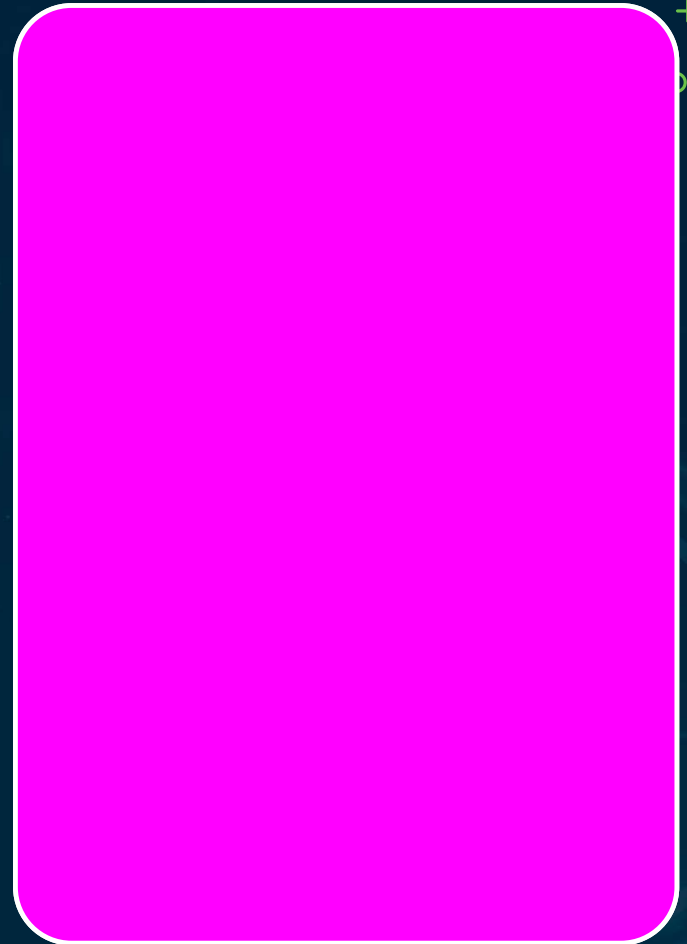
Exam Tips

Five principles — definition, implementation, violation each

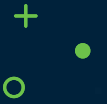
Fairness: demographic parity vs equal opportunity

Privacy: three risks beyond compliance

LIME (local approx) vs SHAP (feature contribution)



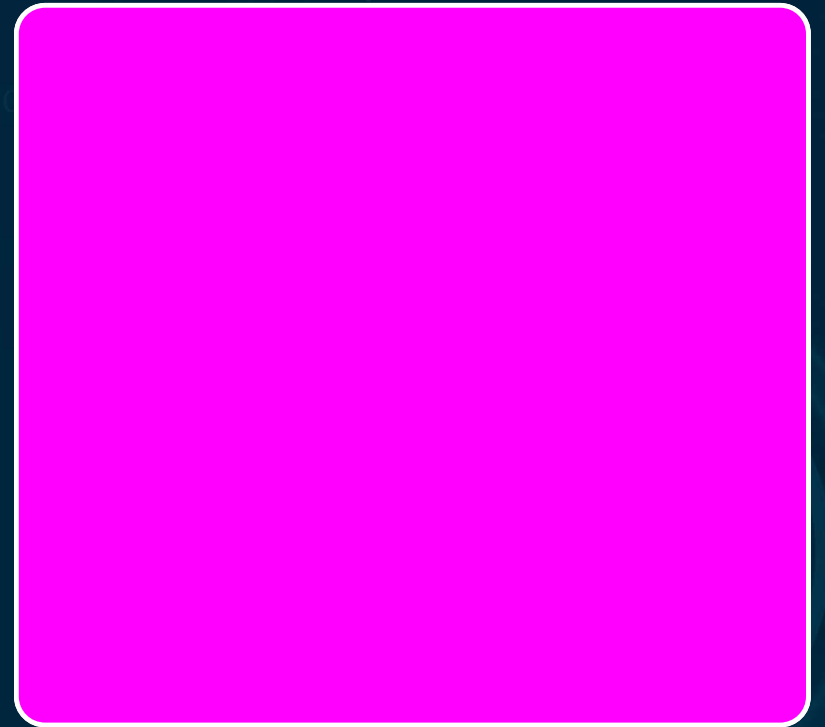
FAIRNESS WITHOUT A METRIC = INTENT



Governance obligations with legal grounding

Explainability without testing fails Article 22

Two legal explainability obligations — documented per system

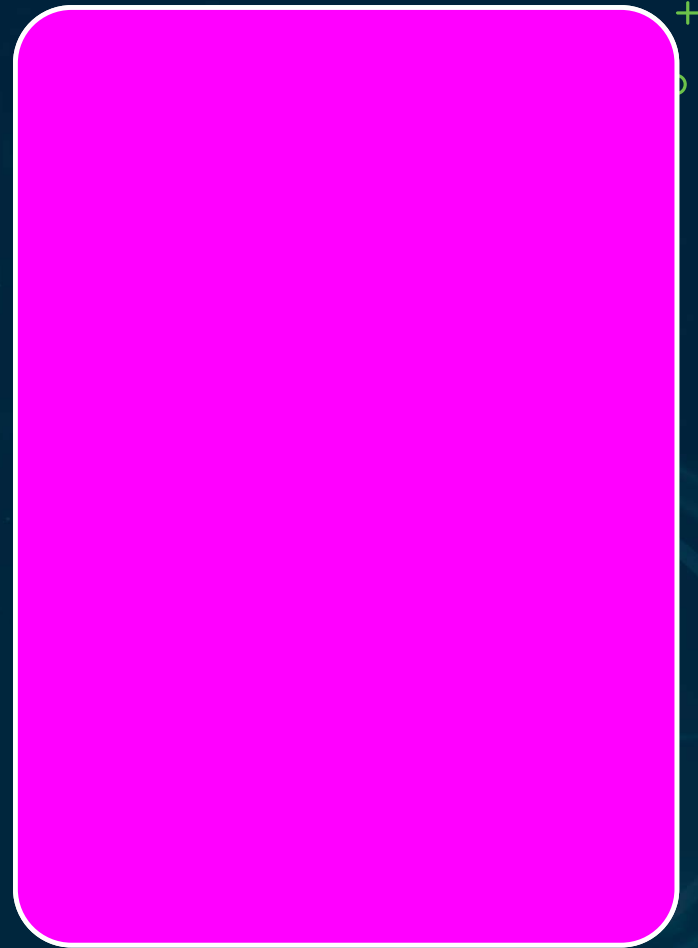


Legal Explainability Obligations

GDPR Article 22 — meaningful explanation for automated decisions

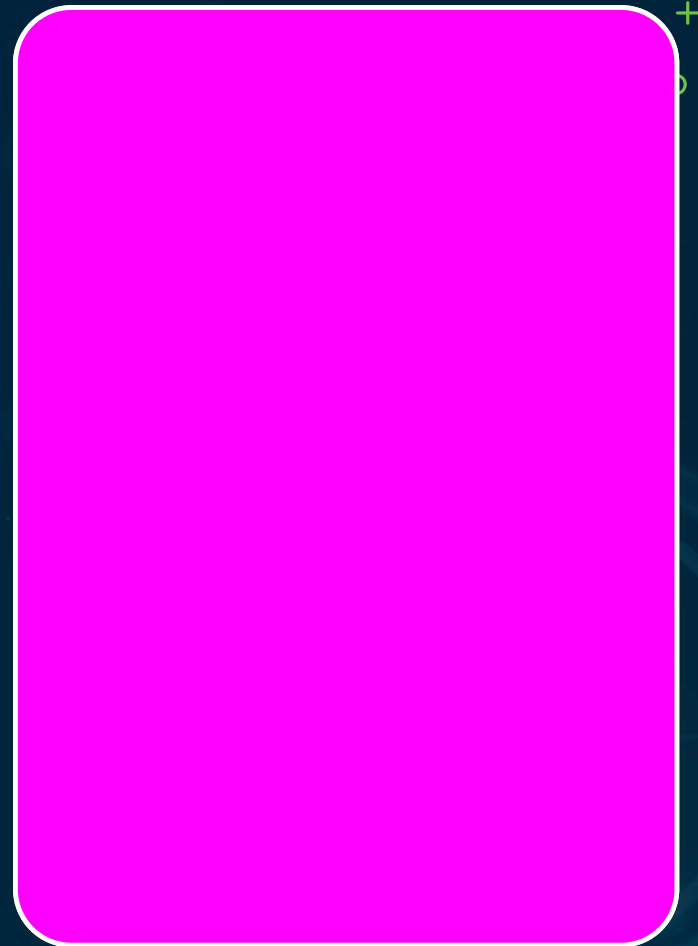
EU AI Act — inform individuals + provide the logic

A SHAP viz that isn't plain language fails Article 22



Six Documentation Requirements

- Responsible-AI policy with testable controls
- Fairness-assessment record
- DPA + FRIA together
- Explainability-mechanism specification
- Trustworthiness assessment + ethics-review record



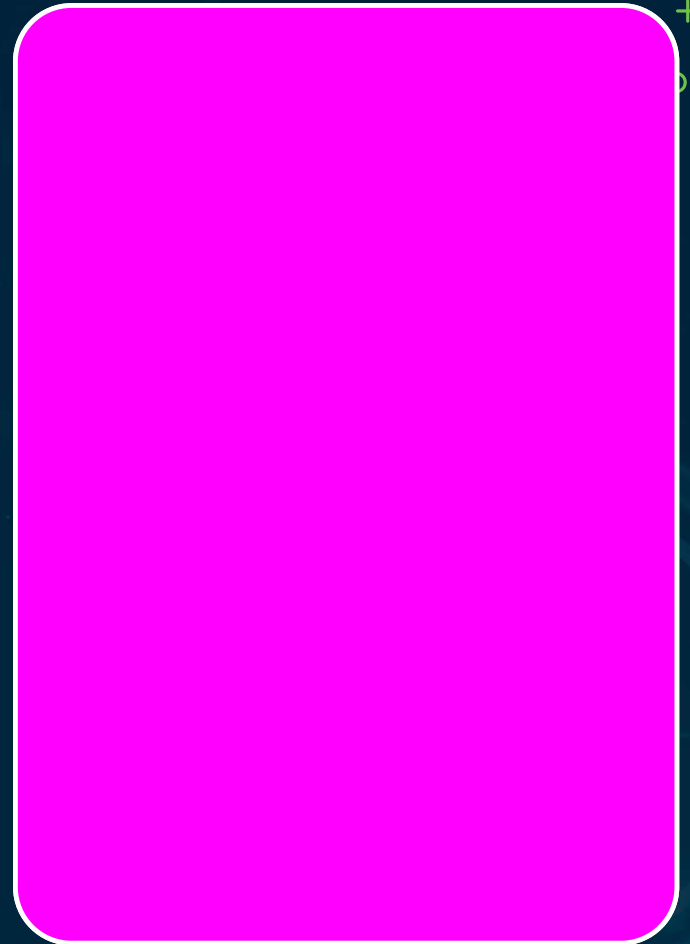
DPA + FRIA & US Context

DPA + FRIA both required for high-risk personal data

Neither substitutes for the other

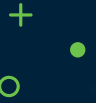
US: no direct Article 22 equivalent — FCRA adverse-action closest

EEOC + California CPRA add automated-decision rights



Control Selection, Implementation & Lifecycle

Chapter 06 · Episode 4 — Dr. Michael Solomon

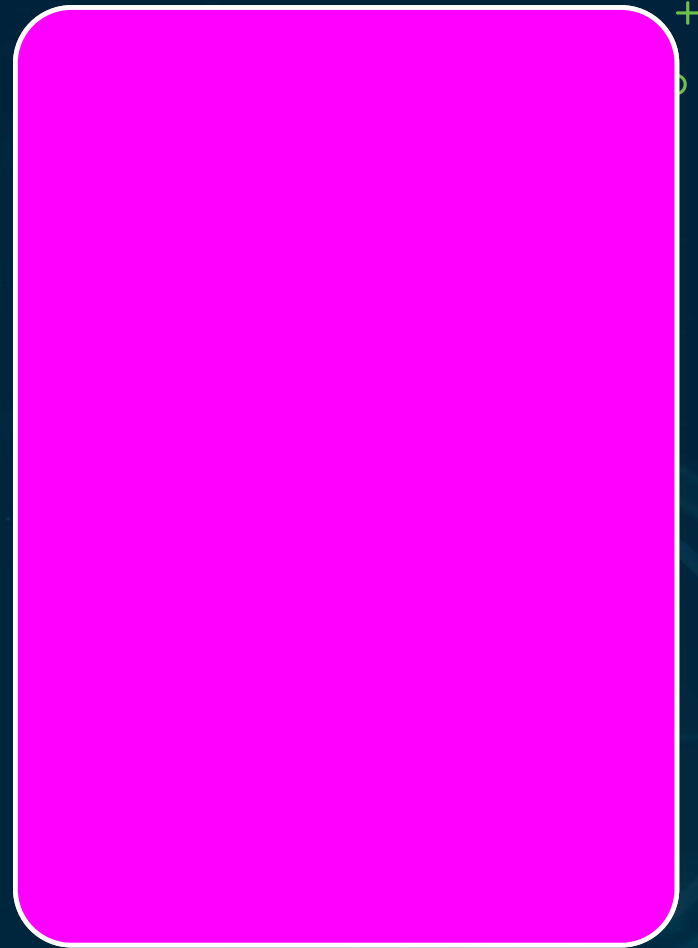


The Control Flow

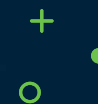
Select → specify → implement

Measure → review → retire

Unbaselined control = intention, not evidence



Selection Criteria 1-4



RISK COVERAGE

Maps to a risk register entry



REG ALIGNMENT

EU AI Act · GDPR · sector



LAYER SCOPE

Which of 4 architecture layers



PROPORTIONALITY

Cost/complexity fits the tier



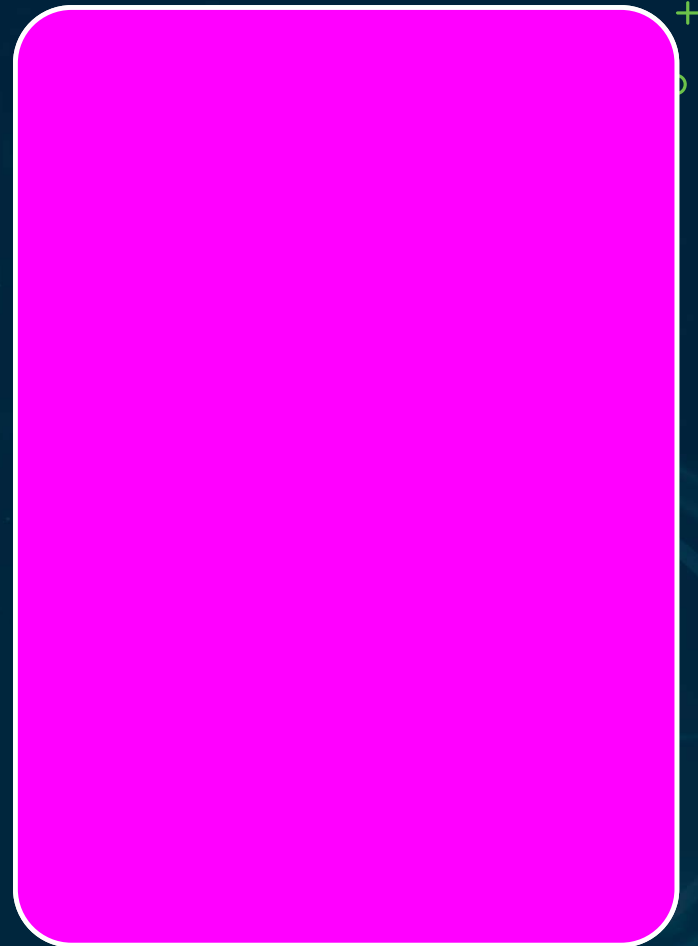
Selection Criteria 5–6

5 Measurability — needs a KPI/KRI

6 Interaction effects — document deps

No KPI/KRI = no demonstration

Silent dependency failure = false assurance



Four Control Layers (≥ 2 each)

RISK COVERAGE

Maps to a risk register entry

REG ALIGNMENT

EU AI Act · GDPR · sector

LAYER SCOPE

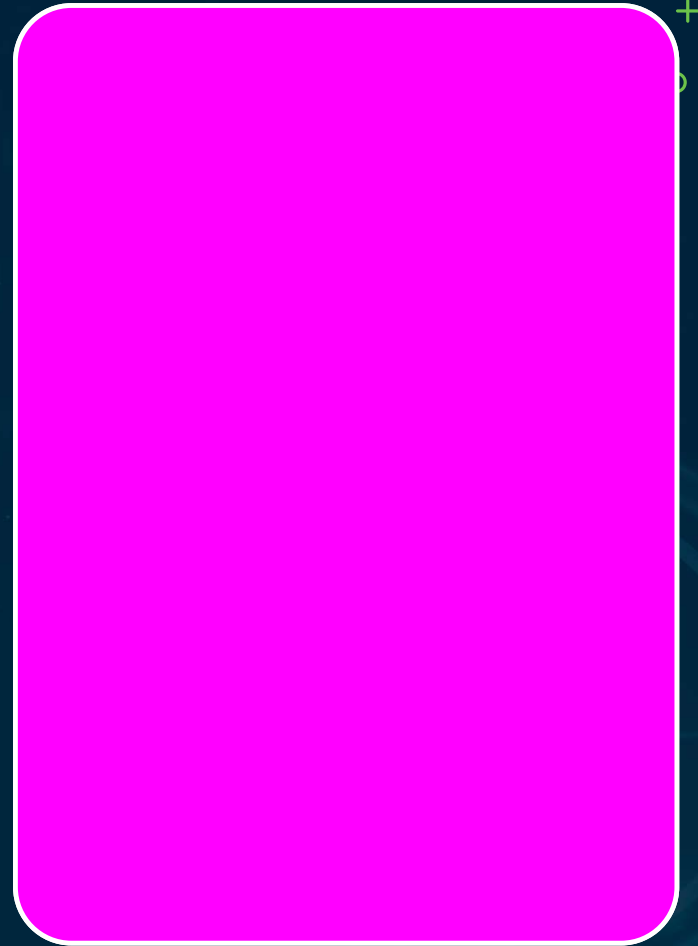
Which of 4 architecture layers

PROPORTIONALITY

Cost/complexity fits the tier

Implementation Plan

- 1 Spec — design · monitors · pass/fail
- 2 Ownership — a named owner
- 3 Acceptance + baseline
- 4 Dependencies + fallback
- 5 Evidence + audit trail



KPI vs KRI

KPI

Control performance

e.g. 99%+ logged

Below → investigate

KRI

Residual risk

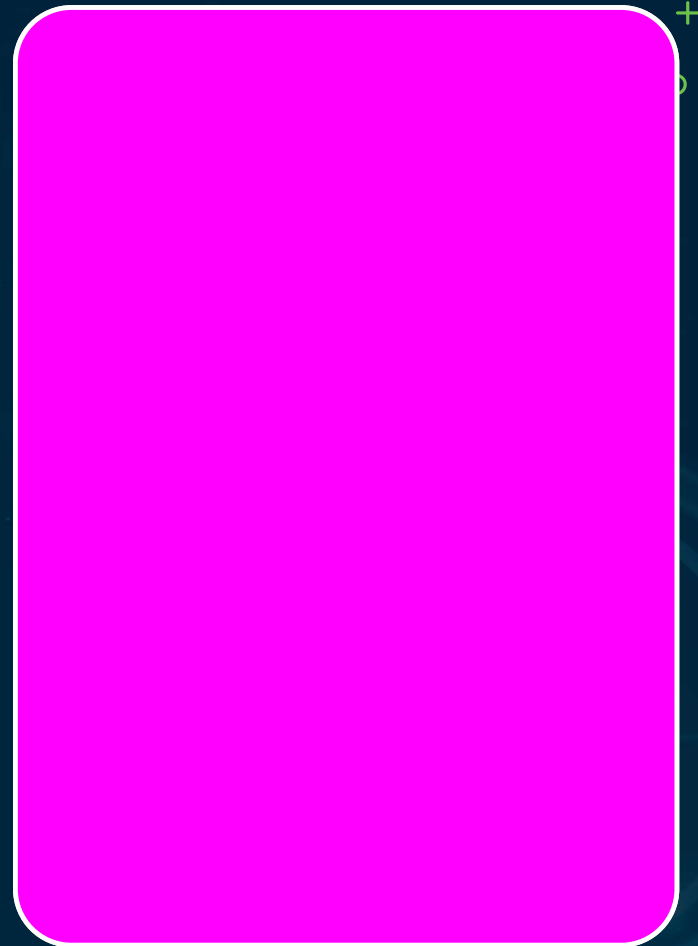
e.g. log gaps / 7 days

Predefined thresholds



Six Lifecycle Phases

- 1 Design→spec
- 2 Implement→baseline
- 3 Monitor→monthly reports
- 4 Assess→effectiveness (annual/bi-annual)
- 5 Enhance→change record
- 6 Retire→sign-off



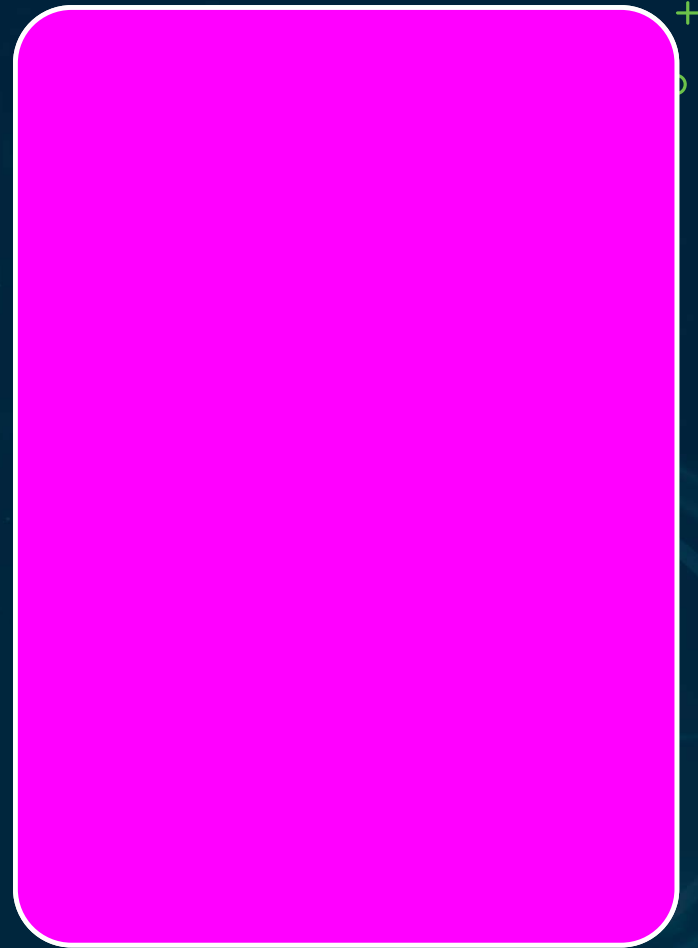
Three Control Gaps

Unimplemented — 4 required elements

Failed — treat as an incident

Vendor-dependent — DD + contract

Unimplemented needs all four elements



Four Lifecycle Failures



NO RISK BASIS

Controls with no register entry



GAP UNDOCUMENTED

Deferred, no register entry



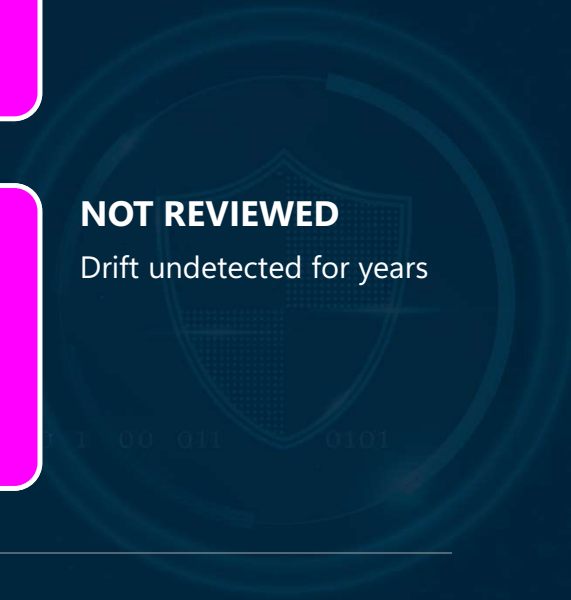
NO BASELINE

Can't tell normal from degraded



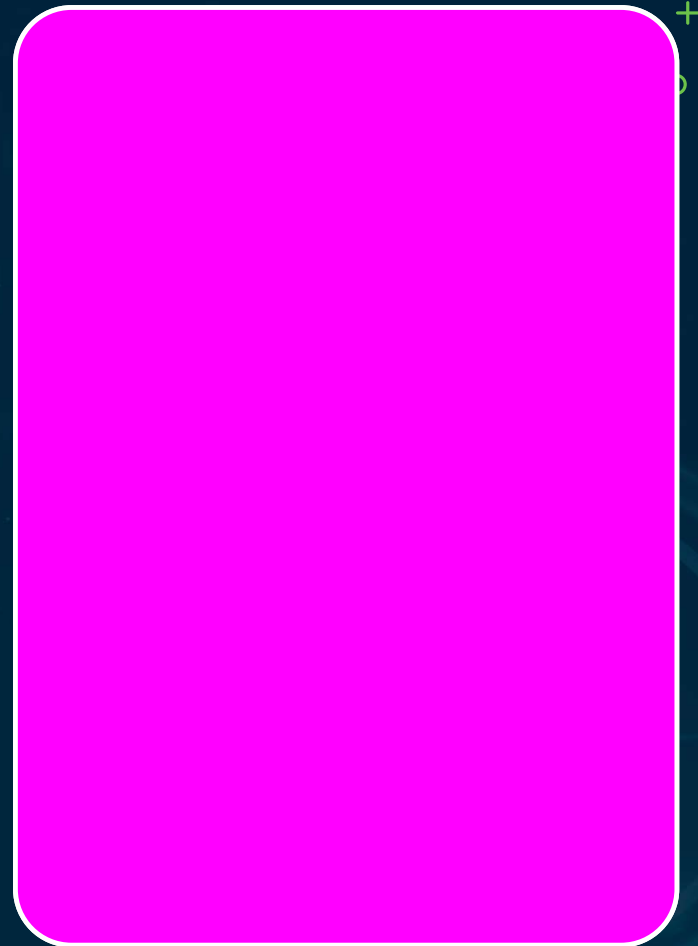
NOT REVIEWED

Drift undetected for years



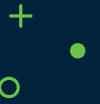
The Fixes + Recap

- Selection starts from the risk register
- Baseline before claiming it works
- Undocumented gap = governance failure
- Annual (tier-1) / bi-annual (tier-2/3) review



Security Monitoring Metrics & Threat Controls Mapping

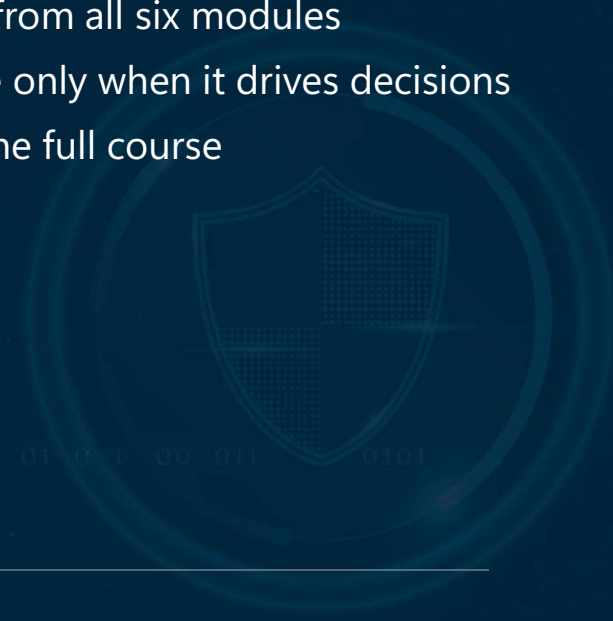
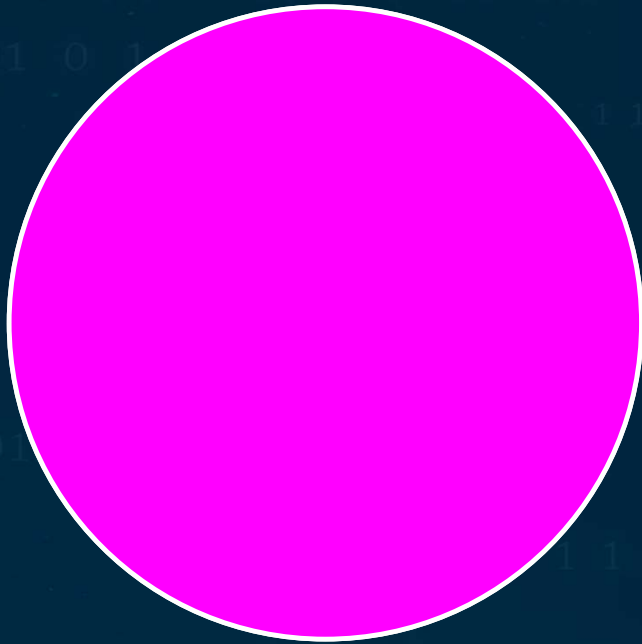
Chapter 06 · Episode 5 — Dr. Michael Solomon





The Monitoring Dashboard

1. Integrates KPIs + KRIs from all six modules
2. Monitoring earns value only when it drives decisions
3. Closes Module 6 and the full course

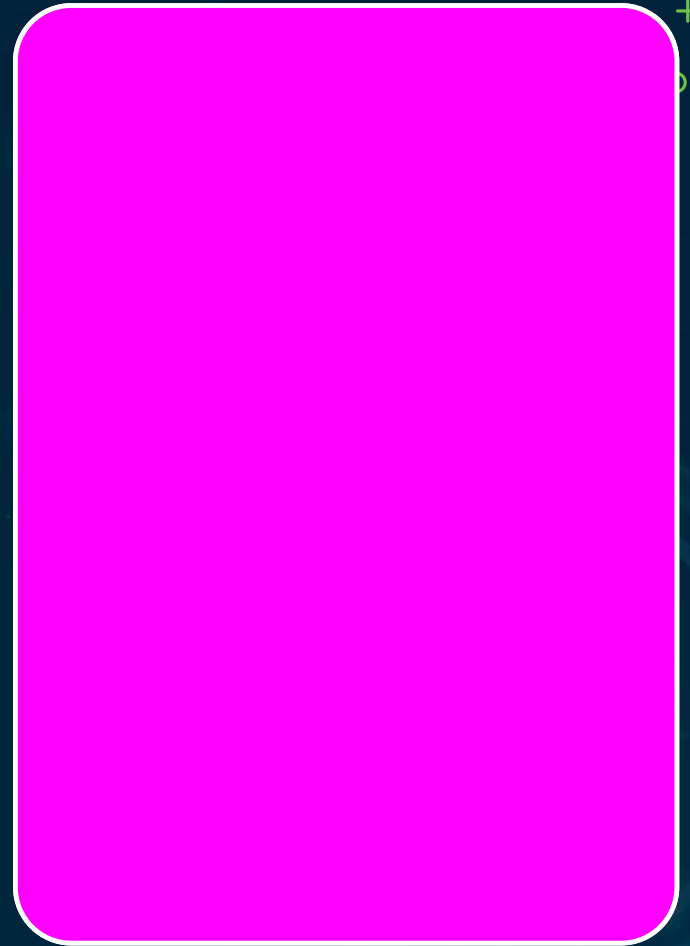


Dashboard · Modules 1–3

M1 Governance — policy-review %; risk entries
>90 days

M2 Data — assets with a current model card

M3 Security — controls with active KPIs

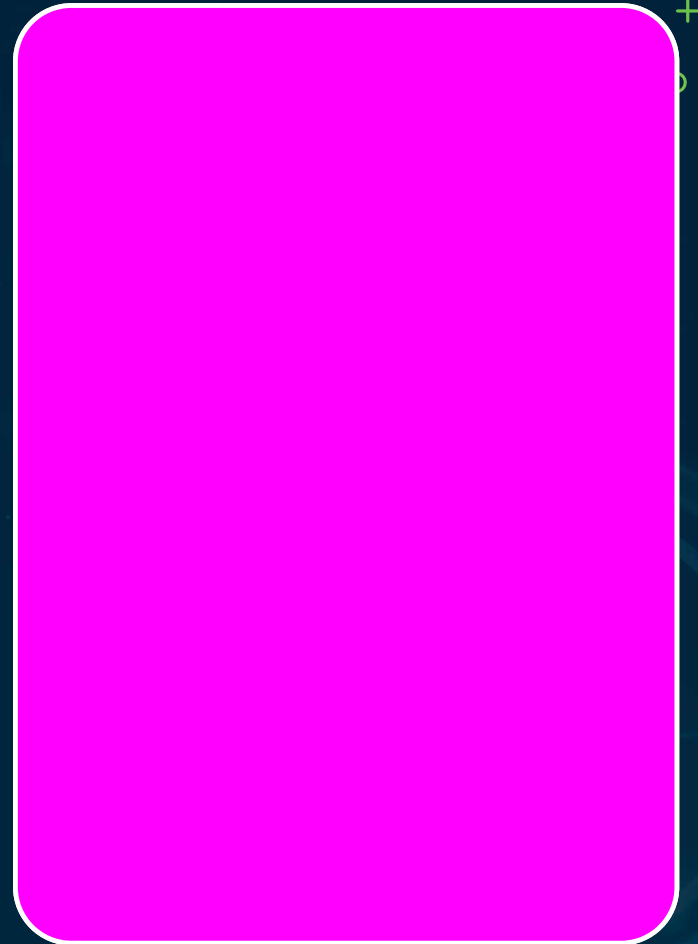


Dashboard • Modules 4–6

M4 Incident/Risk — mean time to detect & contain

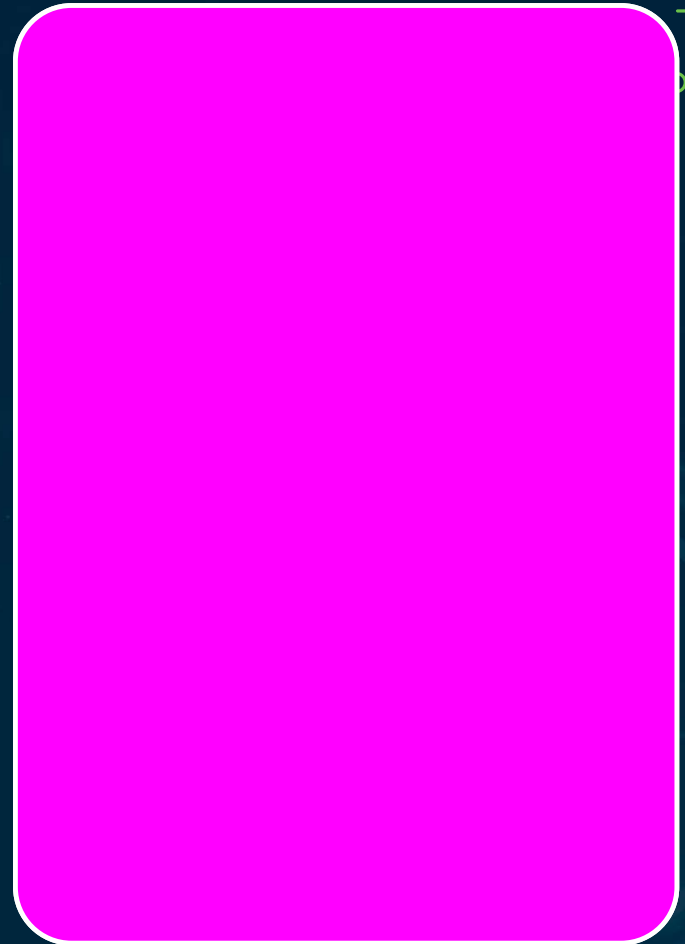
M5 Vendor — third-party monitoring completion

M6 Controls — % controls meeting baseline



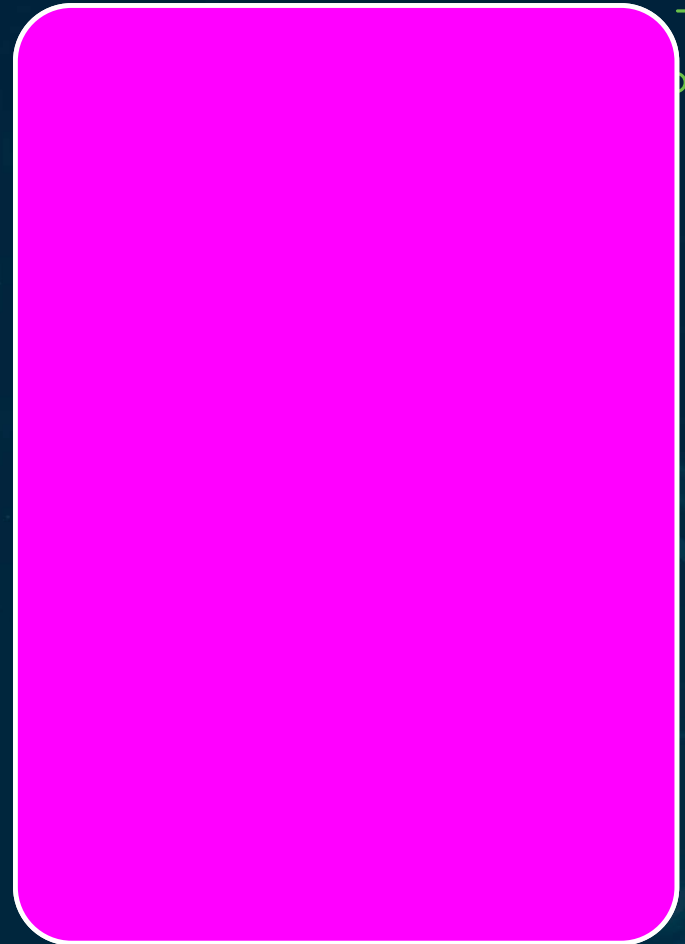
Six AI-Specific SIEM Sources

- Inference logs
- Training-pipeline logs
- Model-registry audit logs
- API-gateway logs
- Fairness metrics
- UEBA AI baselines



Six Detection Rule Categories

- Prompt injection
- Model extraction
- Training-data anomalies
- Output anomalies
- Insider threat
- Supply-chain alerts



Seven MITRE ATLAS Threat Mappings

ML supply-chain compromise

Data poisoning

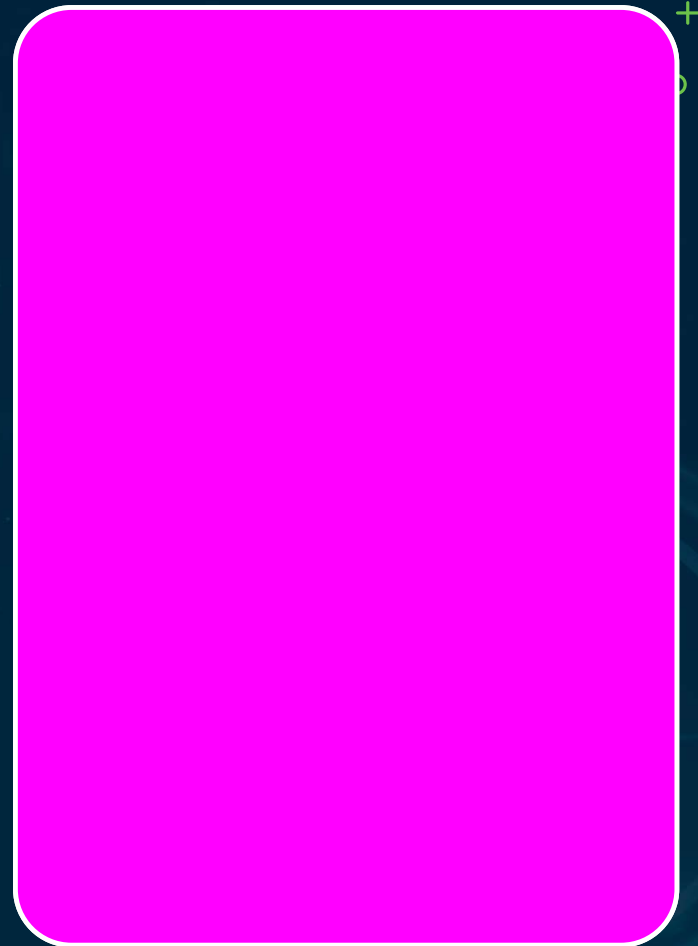
Model evasion

Model extraction

Prompt injection

Insider threat

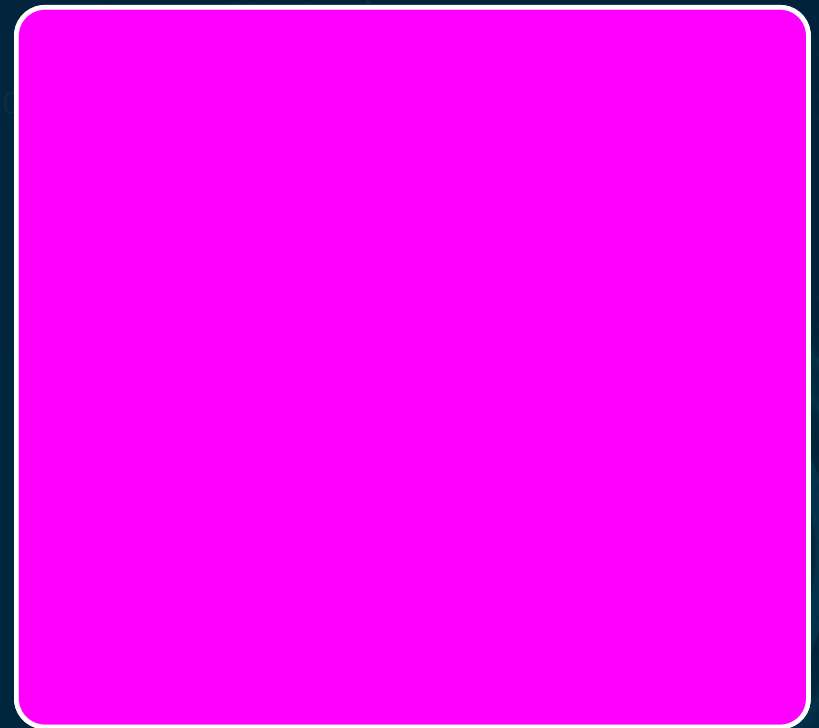
Membership inference



UNMANAGED RISK

Each threat needs a primary control, a detection control + documented residual risk

Threat + no risk-register entry = unmanaged risk



Four Monitoring Maturity Levels

L1 Reactive

Post-harm; no continuous evidence

L2 Basic

Delayed periodic evidence only

L3 Active

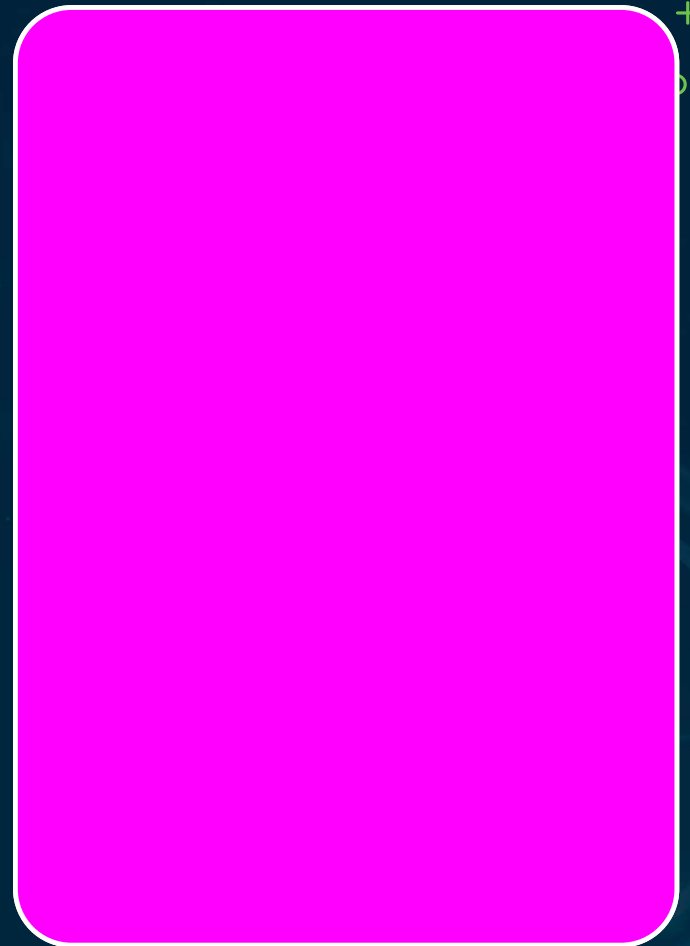
Continuous KPI/KRI + alerts
— EU AI Act min

L4 Assurance

Predictive, self-improving;
strongest evidence

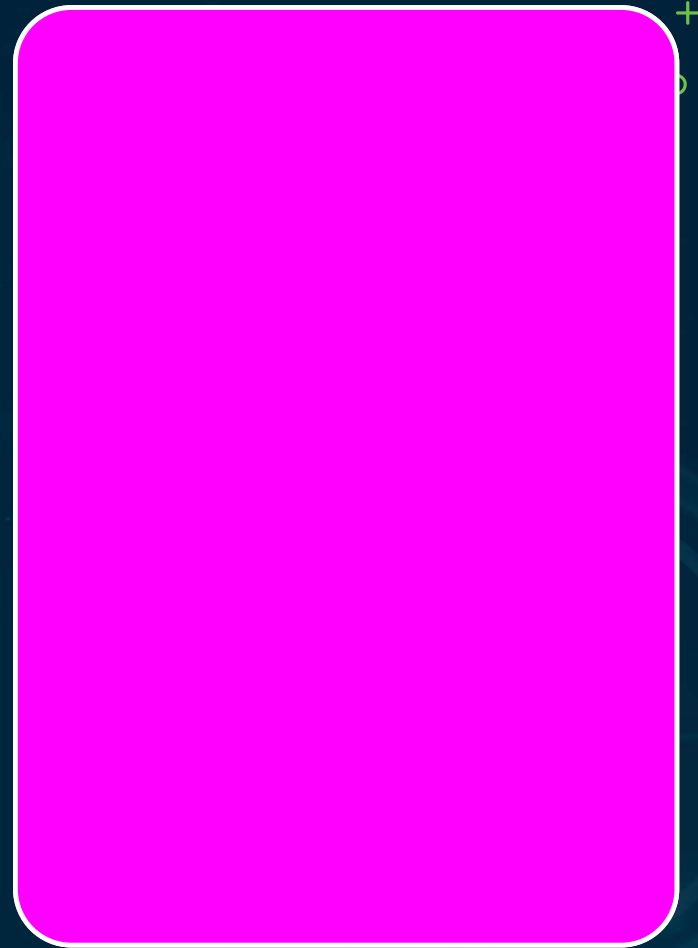
Monitoring Cycle · Steps 1–3

- 1 Collect — six SIEM sources, documented in plan
- 2 Detect — rules + correlation raise alerts
- 3 Analyze — triage, classify, record findings



Monitoring Cycle · Steps 4–6

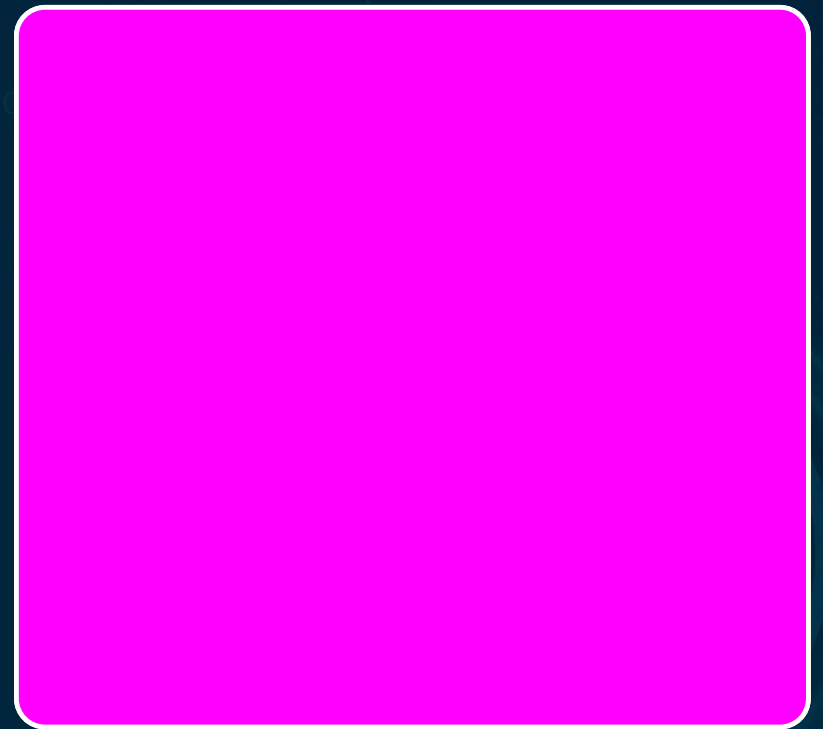
- 4 Respond — IR + risk-register updates, logged
- 5 Report — monthly / quarterly / board cadence
- 6 Improve — tune rules, add sources



IMPROVE = L3 → L4

Self-improvement is the maturity signal

The improve step distinguishes Level 3 from Level 4



Module 6 Complete — The Thread

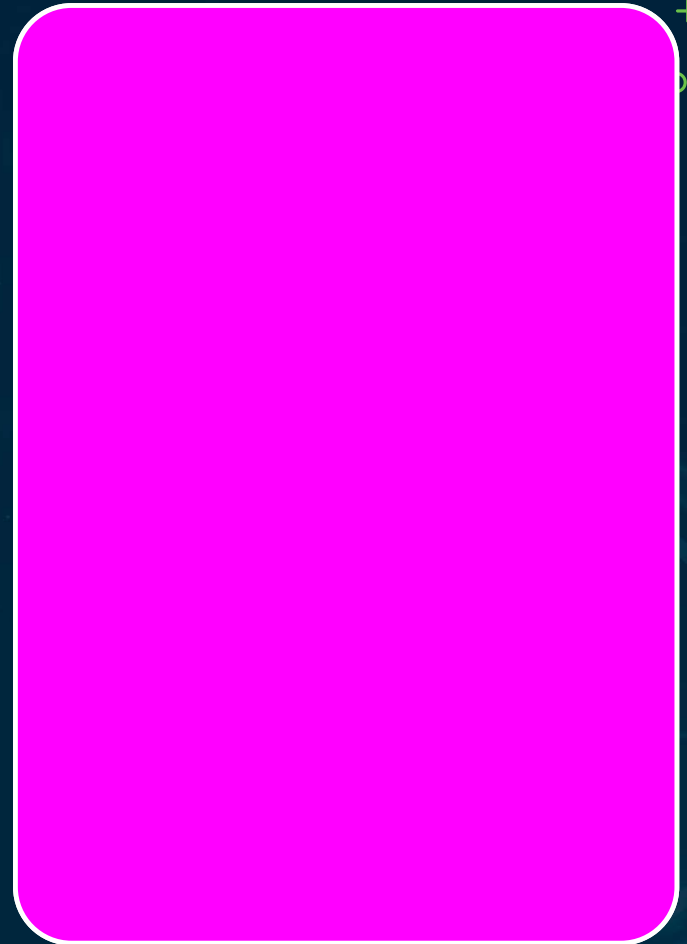
Testing & TEVV

Data management & poisoning

Privacy, ethics & trust

Control lifecycle

Monitoring & controls mapping



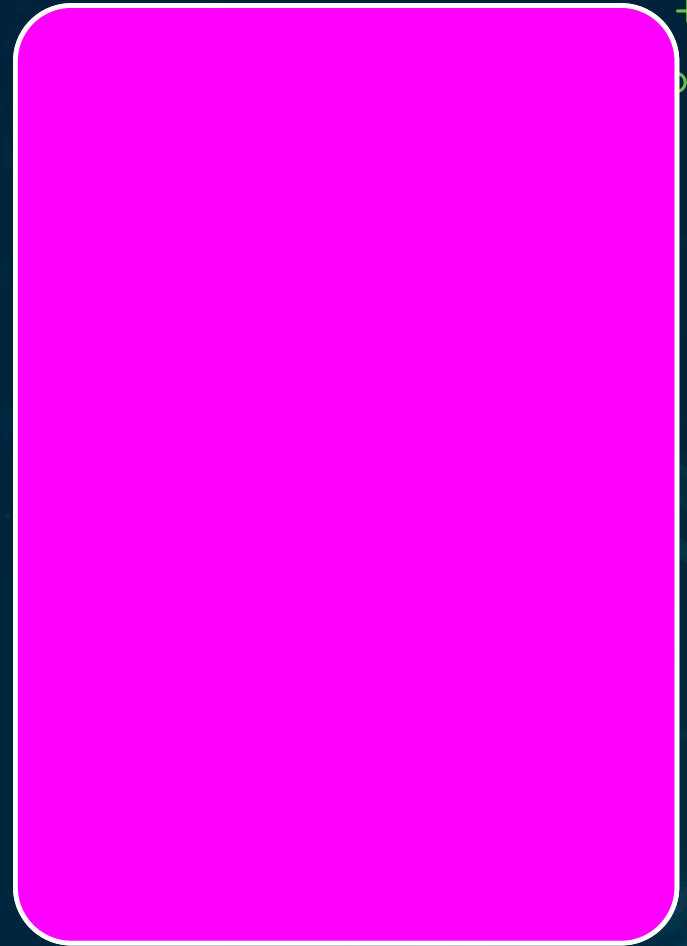
Governance Documents = Evidence

Asset inventory — proves what you govern

Risk register — proves you assessed it

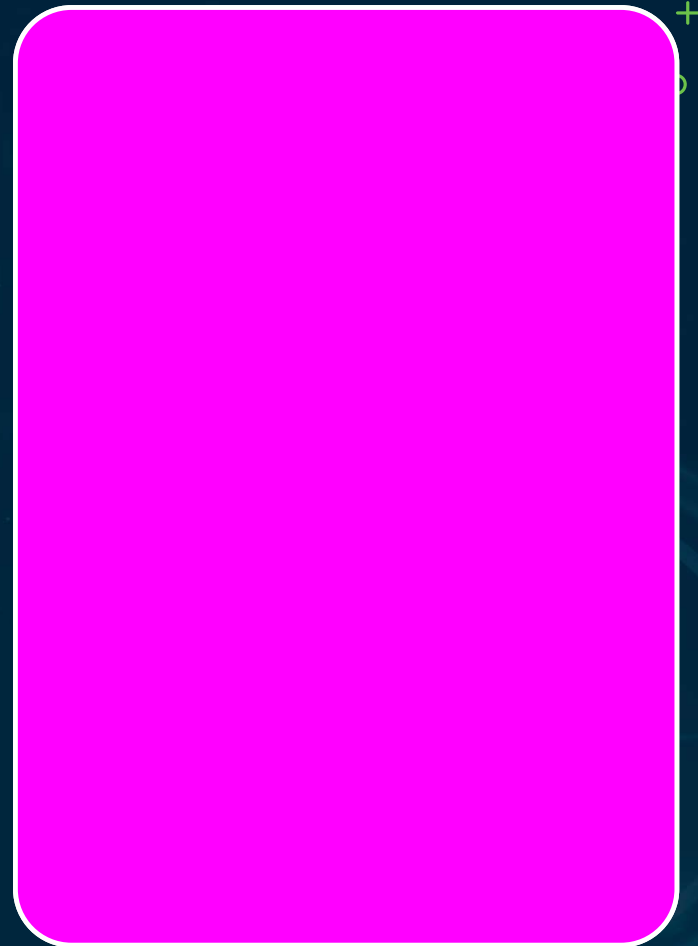
Control specs — prove you addressed it

Monitoring records — prove you maintained it



The Program Must / Must Not

- Start every control from the risk register
- Treat V&V completion as a deployment gate
- Not accept "publicly available" as a license
- Not treat model updates as software patches



What the Exam Tests

Provider vs deployer + 4 deemed-provider cases

TEVV vs V&V; 6 control-lifecycle phases

6 monitoring-cycle steps; 5 poisoning-response steps

8 architecture-review checklist items

